

IDS IPS Suricata



Grau Superior en Administració de Sistemes Informàtics en Xarxa (ASIX 2)

Mòdul: M0379 - Miniprojecte

Autors: Izan Ruiz, Youssef Fouad, Adrià Rodríguez

Institut: INS Sa Palomera

Curs Acadèmic: 2025 - 2026

1. Introducció als Sistemes de Detecció i Prevenció d'Intrusions (IDS/IPS)	5
1.1. Conceptes Bàsics: IDS vs IPS	5
1.2. Metodologies de Detecció	6
1.3. Amenaces Comunes i Casos d'Ús	6
2. Selecció de la Tecnologia: Comparativa d'eines	7
2.1. Comparativa de Sistemes IDS/IPS	7
2.2. Justificació de l'elecció i Requisits de Maquinari	8
2.3. Requisits de Maquinari (VirtualBox):	9
3. Instal·lació i Configuració de Suricata	9
3.1. Preparació del Sistema i Instal·lació	9
3.2. Configuració de la Interfície de Xarxa	10
3.3. Accés a PfSense i Configuració Inicial	11
4. Definició de Polítiques de Seguretat	12
4.1. Selecció de signatures	12
4.2. Actualització del motor de detecció	13
4.3. Implementació de la Instància de Vigilància	13
4.4. Configuració de polítiques per a diferents zones de la xarxa	14
4.5. Establiment de mecanismes de resposta a incidents	16
4.6. Configuració avançada del sistema de Logs (EVE JSON)	18
5. Simulació d'Atacs i Resposta	20
5.1. Implementació de Regles Personalitzades	20
Anàlisi General de les Regles Implementades	20
Lògica de Configuració: L'ús de any	21
5.2. Pentesting de la xarxa LAN	21
Prova 1: Escaneig de Ports (Nmap NULL Scan)	21
Prova 2: Escaneig de vulnerabilitats amb Nikto	22
Prova 3: Atac de Força Bruta contra SSH (Hydra)	23
Prova 4: Enumeració de Directoris amb DIRB	24
Prova 5: Atac de Denegació de Servei (DoS) amb hping3	25
Prova 6: Seguretat en la descàrrega de programari i control de trànsit	25
Prova 7: Detecció de Protocols Insegurs (Telnet)	27
5.3. Pentesting de la xarxa WAN	28
Prova 1: Escaneig de reconeixement i detecció de serveis (Nmap)	29
Prova 2 : Atac de Denegació de Servei	30
Prova 3 : Regle Personalitzada (PING)	30
Prova 4: Bloqueig de Protocols Insegurs (Telnet)	31
Prova 5 (WAN): Atac de Força Bruta al servei SSH (Hydra)	32
Prova 6 (WAN): Atac d'Injecció SQL (sqlmap)	34
Prova Final (WAN): Verificació de l'IPS mitjançant Fingerprinting (WAFW00F)	35
6. Configuració de Sistemes Complementaris	38

Pas 1: Identificació i Preparació del Fitxer de Logs	38
Pas 2: Desenvolupament del Script de Notificació en PHP	38
Pas 3: Automatització mitjançant el Servei Cron	39
Pas 4: Verificació i Prova d'Intrusió en Temps Real	40
6.1. Pla d'Acció i Resposta Davant d'Alertes Críiques	41
Fase 1: Triatge i Avaluació Inicial (Triage)	41
Fase 2: Contenció i Aïllament de Xarxa	41
Fase 3: Anàlisi Bàsic	41
Fase 4: Erradicació i Recuperació	41
Fase 5: Documentació i Tuning	41
7. Filtratge de Continguts i Seguretat de Navegació (pfBlockerNG)	42
Pas 1: Instal·lació del Paquet	42
Pas 2: Configuració del DNSBL	42
Pas 3: Actualització forçada (Force Update)	43
Pas 4: Definició de la Virtual IP	43
5: Proves de Funcionament i Validació del Sistema	44
Pas 6: Configuració de Regles i Llistes Personalitzades	44
7: Prova de Bloqueig	45
8. Optimització del rendiment del sistema IDS/IPS	46
8.1. Ajust del motor de detecció (Flow/Stream)	46
8.2. Optimització de signatures	47
9. Webgrafia i Referències Tècniques	50
Documentació Oficial i Motor IDS/IPS:	50
Eines d'Auditoria i Pentesting (Kali Linux):	50
Sistemes Complementaris i Programació:	51
Eines de Suport i Intel·ligència Artificial:	51

INS Sa Palomera

ASIX – Projecte Final de Curs 2025-2026

Grup: Izan Ruiz · Youssef Fouad · Adrià Rodríguez

INS Sa Palomera

ASIX – Projecte Final de Curs 2025-2026

Grup: Izan Ruiz · Youssef Fouad · Adrià Rodríguez

1. Introducció als Sistemes de Detecció i Prevenció d'Intrusions (IDS/IPS)

Avui en dia, fiar-nos únicament d'un tallafocs firewall per protegir la nostra xarxa perimetral ja no és suficient.

Aquí és on entren els sistemes de detecció i prevenció d'intrusions (IDS i IPS). Aquests sistemes fan una inspecció profunda, analitzen el contingut real dels paquets de dades que circulen per la xarxa per identificar atacs o comportaments maliciosos que han aconseguit camuflar-se i travessar les primeres defenses.

1.1. Conceptes Bàsics: IDS vs IPS

A l'hora de dissenyar la seguretat d'una xarxa, és fonamental entendre la diferència entre aplicar una estratègia de detecció passiva o una de prevenció activa:

- **IDS (Intrusion Detection System - Detecció passiva):** Funciona estrictament com un sistema de monitorització. Es dedica a escoltar tot el trànsit de la xarxa o a revisar els registres (logs) buscant qualsevol activitat sospitosa. Si detecta un atac, la seva única funció és generar una alerta per avisar l'administrador. No intervé mai en el trànsit ni talla les connexions. Podríem dir que actua com una càmera de videovigilància: grava i avisa si entra un lladre, però no l'atura.
- **IPS (Intrusion Prevention System - Prevenció activa):** És l'evolució directa de l'IDS. A més de tenir tota la capacitat per detectar les amenaces, té l'autoritat i la capacitat tècnica per actuar al moment. Quan un IPS detecta un paquet maliciós, executa accions de bloqueig automàtiques en temps real. Pot tallar la connexió immediatament, bloquejar la IP de l'atacant o descartar els paquets perillosos, protegint la infraestructura abans que el dany estigui fet.

1.2. Metodologies de Detecció

Per poder identificar quins paquets són legítims i quins són un perill, aquests sistemes treballen principalment combinant dos mètodes d'anàlisi:

- **Detecció basada en signatures:** És el mètode més tradicional i funciona de manera molt semblant a un antivirus clàssic. El sistema descarrega i actualitza constantment una gran base de dades que conté signatures o patrons d'atacs que ja són coneguts arreu del món. Quan el trànsit de la nostra xarxa coincideix exactament amb un d'aquests patrons, el sistema fa saltar l'alarma. És un mètode molt ràpid i eficaç contra amenaces habituals, però té un punt feble: és inútil contra atacs totalment nous que encara no estan registrats (els anomenats atacs Zero-Day).
- **Detecció basada en anomalies:** Per solucionar el problema dels atacs nous, s'utilitza aquest segon mètode. El sistema passa un temps "aprenent" com funciona normalment la nostra xarxa (quin volum de dades es mou, a quines hores hi ha més trànsit, quins ports s'utilitzen, etc.) per crear una línia base de comportament normal. Un cop ho ha après, si detecta qualsevol activitat inusual que surt d'aquesta normalitat (com per exemple un ordinador enviant gigues de dades de matinada o un escaneig massiu de ports), dispara una alerta automàticament.

1.3. Amenaces Comunes i Casos d'Ús

La implementació d'aquest tipus de sistemes al nostre projecte no és un caprici teòric, sinó una necessitat real per mitigar perills molt freqüents a Internet. Un IDS/IPS ens protegeix de manera efectiva contra:

- **Escaneig de ports i reconeixement:** Ens permet detectar ràpidament quan un atacant està sondejant la nostra xarxa des de fora per fer un mapa dels nostres equips i buscar possibles vulnerabilitats o portes obertes.
- **Atacs de Força Bruta:** Detecta i frena els intents massius i repetitius d'iniciar sessió provant milers de contrasenyes per segon en serveis crítics, com ara connexions remotes (SSH, RDP) o panells d'administració web.
- **Exploits coneguts:** Bloqueja els atacs dirigits directament contra programari que tenim instal·lat però que potser no hem actualitzat a l'última versió (per exemple, un atac dissenyat per aprofitar un forat de seguretat específic d'un servidor web Apache).

- **Atacs de Denegació de Servei (DoS i DDoS):** Identifica inundacions de trànsit brossa que tenen com a únic objectiu saturar la nostra xarxa o els nostres servidors fins a fer-los caure i deixar els nostres serveis fora de línia.
- **Injecció de Codi (SQLi / XSS):** Analitza les dades que els usuaris envien a través de formularis web per bloquejar aquells que intenten introduir codi maliciós per manipular la nostra base de dades o executar scripts perillosos.

2. Selecció de la Tecnologia: Comparativa d'eines

Abans de començar a muntar el nostre escenari, el primer pas ha estat decidir quina eina utilitzaríem com a motor del nostre sistema de seguretat. Actualment, a la indústria hi ha diverses solucions de codi obert (gratuïtes i mantingudes per la comunitat) que són molt potents i s'utilitzen en entorns professionals reals.

Per triar la millor opció, hem analitzat i comparat les tres eines més destacades del mercat actual: Snort, Suricata i Wazuh.

2.1. Comparativa de Sistemes IDS/IPS

Característica	Snort	Suricata	Wazuh
Tipus	NIDS (Analitza la xarxa des de fora)	NIDS / IPS (Analitza i bloqueja a la xarxa)	HIDS (S'instal·la dins dels equips com un agent)
Arquitectura	Monofil (Només aprofita un nucli del processador)	Multi-fil (Aprofita tots els nuclis del processador)	Basada en agents instal·lats als ordinadors
Rendiment	Bo, però pateix si la xarxa és molt gran	Excel·lent, preparat per a xarxes d'alta velocitat	Molt lleuger, no satura els servidors

Inspecció	Basada principalment en signatures bàsiques	Signatures i protocols avançats (Capa 7)	Llegeix logs, busca vulnerabilitats i vigila fitxers
Comunitat	És l'eina més antiga i amb més documentació	Molt activa, moderna i amb actualitzacions constants	En gran creixement (Evolucionant cap a plataformes globals com SIEM)

Com podem extreure d'aquesta comparativa, Snort és un clàssic de la ciberseguretat, però el seu disseny és més antic. Wazuh és una eina fantàstica, però el seu funcionament és diferent: funciona instal·lant petits programes a cada ordinador per vigilar-los per dins. Finalment, Suricata es presenta com l'evolució dels 3, ja que pot vigilar tota la xarxa des d'un sol punt, aprofita tots els nuclis del processador i permet bloquejar atacs activament.

2.2. Justificació de l'elecció i Requisits de Maquinari

Com que l'objectiu principal d'aquest projecte és muntar un sistema de detecció i prevenció d'intrusions (IDS/IPS) realista i aplicable a l'entorn laboral, hem decidit treballar amb la combinació de pfSense i Suricata. Aquesta decisió es basa en quatre motius fonamentals:

- **Solució centralitzada:** pfSense és un sistema operatiu dissenyat específicament per fer de router i tallafocs. Instal·lar-hi Suricata directament com un paquet addicional ens permet gestionar tant les regles del tallafocs com les alertes de l'IPS des de la mateixa interfície web. Això és exactament el que fan les empreses amb els seus tallafocs professionals.
- **Alt rendiment en entorns virtuals:** A l'hora de muntar-ho al nostre VirtualBox, Suricata té un avantatge decisiu gràcies a la seva arquitectura multi-fil (multithreading). Això vol dir que sap repartir la feina entre diversos processadors virtuals, funcionant de manera molt més fluida i aprofitant millor els recursos del nostre ordinador.
- **Mode IPS:** Ens permetrà configurar pfSense perquè Suricata no només ens envii un avís quan ens ataquen, sinó que bloquegi els atacs en temps real tallant el trànsit de l'atacant.

- **Sortida de dades moderna (EVE JSON):** En lloc de generar fitxers de text difícils de llegir, Suricata genera logs en un format estructurat i modern anomenat EVE JSON. Això ens permetrà integrar fàcilment aquestes alertes amb panells visuals o sistemes de monitorització que ja tenim muntats, com per exemple Zabbix(en un futur).

2.3. Requisits de Maquinari (VirtualBox):

L'anàlisi de paquets en temps real i la càrrega de milers de signatures (regles de seguretat) consumeixen bastants recursos. Per garantir que el sistema funcioni bé, vagi fluid i no es pengi en carregar les regles de Suricata, a la màquina virtual de pfSense li hem assignat:

- **RAM:** 8 GB. (Imprescindible per carregar les llistes d'amenaces a la memòria).
- **CPU:** 4 nuclis. (Per poder treure profit del multi-fil de Suricata).
- **Xarxa:** 2 targetes de xarxa. Una farà de WAN (connectada a Internet per rebre el trànsit de fora) i l'altra farà de LAN (la nostra xarxa interna que volem protegir).

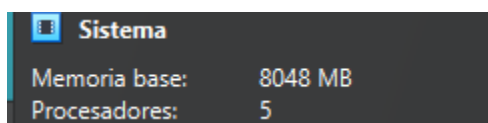
3. Instal·lació i Configuració de Suricata

Per muntar el nostre laboratori, no hem instal·lat Suricata directament sobre un Windows o un Linux, sinó que hem partit de la imatge ISO oficial de pfSense. Aquest sistema operatiu serà la base del nostre tallafocs i a sobre hi instal·larem el motor de suricata.

3.1. Preparació del Sistema i Instal·lació

Partint de la imatge ISO de pfSense, hem muntat el nostre entorn de pràctiques seguint aquests passos:

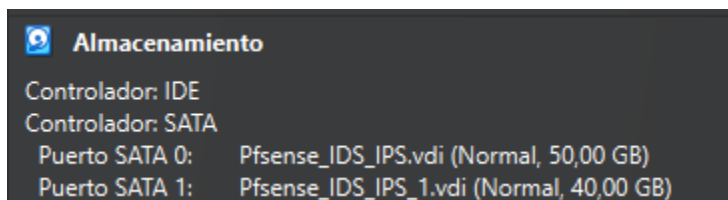
1. **Creació de la Màquina Virtual:** Com hem comentat als requisits, hem creat una màquina amb 8 GB de memòria RAM i 4 nuclis de processador. Aquesta potència és clau perquè el sistema pugui analitzar tot el trànsit sense convertir-se en un coll d'ampolla per a la nostra xarxa.



2. **Instal·lació de l'emmagatzematge:** Un dels problemes més habituals en els sistemes de detecció (IDS) és que generen tantes alertes i tants registres (logs) que poden omplir el disc dur ràpidament. Si el disc s'omple, el sistema operatiu pot caure. Per evitar aquest problema de rendiment i estabilitat, hem configurat la màquina virtual amb dos discos durs separats:

Disc 1: Dedicat exclusivament a instal·lar-hi el sistema operatiu base (pfSense) i guardar-hi la seva configuració.

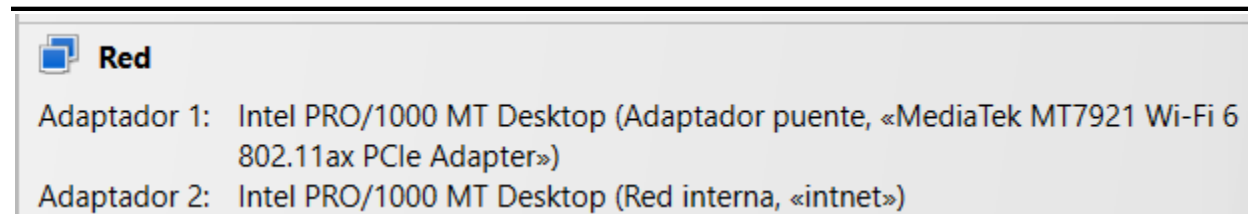
Disc 2: Aquest disc l'hem reservat per muntar-hi la partició /var/log. D'aquesta manera, tots els registres del sistema i les milers d'alertes de Suricata s'escriuran aquí. Si mai s'omple aquest disc d'alertes, el firewall seguirà funcionant sense penjar-se.



3.2. Configuració de la Interfície de Xarxa

Com que pfSense actua com un tallafocs, necessita estar just al mig de dues xarxes per poder controlar qui entra i qui surt. Per això, el pas més important a VirtualBox ha estat configurar-li dues targetes de xarxa diferents:

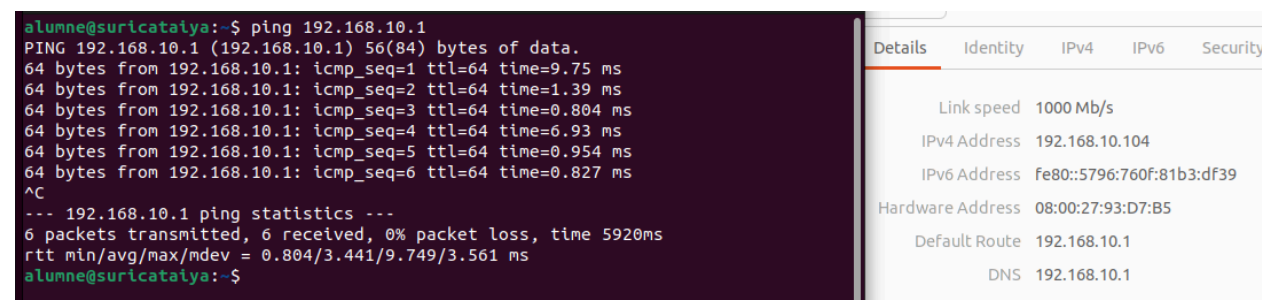
- **Adaptador 1 WAN** Aquest adaptador l'hem configurat en mode "Adaptador Pont" (Bridge). Serveix perquè el nostre pfSense tingui sortida a Internet a través del nostre ordinador físic. Serà la interfície per on rebrem tots els possibles atacs exteriors.
- **Adaptador 2:** Aquest adaptador l'hem configurat com a "Xarxa Interna". Representa la nostra xarxa segura i privada, on hi connectarem les màquines dels usuaris (clients) que volem protegir.



Un cop instal·lat pfSense, l'hem engegat i, des de la línia de comandes (la pantalla negra inicial), hem assignat les IPs a cada targeta:

```
*** Welcome to pfSense 2.7.2-RELEASE (amd64) on pfSense ***
WAN (wan)          -> em0          -> v4/DHCP4: 10.93.255.38/16
LAN (lan)           -> em1          -> v4: 192.168.10.1/24
```

- **Assignació d'IPs:** Li hem dit al sistema que la targeta em0 és la WAN (i agafa la IP automàticament per DHCP per tenir Internet) i que la targeta em1 és la LAN. A la LAN li hem posat la IP fixa 192.168.10.1. Aquesta IP serà la porta d'enllaç dels nostres ordinadors interns.
- **Verificació de connectivitat:** Abans de tocar res més, hem encès un ordinador client connectat a la Xarxa Interna i hem fet un ping a la IP 192.168.10.1. En veure que responia bé, hem confirmat que la xarxa funciona i podem passar a instal·lar l'antivirus de xarxa.



3.3. Accés a PfSense i Configuració Inicial

Amb la xarxa funcionant correctament i l'accés a Internet garantit, hem obert un navegador web des de la nostra màquina client interna i hem entrat a la interfície gràfica de pfSense (WebGUI) posant la IP 192.168.10.1.

Un cop a dins, el procés ha estat molt senzill pfSense té un apartat anomenat "Gestor de Paquets" (Package Manager) que funciona com la botiga d'aplicacions. Hem buscat el paquet oficial de Suricata i l'hem instal·lat amb un sol clic. D'aquesta manera, el motor de seguretat ja queda perfectament integrat amb el sistema operatiu del tallafocs.

Installed Packages					
Name	Category	Version	Description	Actions	
✓ suricata	security	7.0.8_1	High Performance Network IDS, IPS and Security Monitoring engine by OISF.	 	
Package Dependencies:					
 suricata-7.0.8					

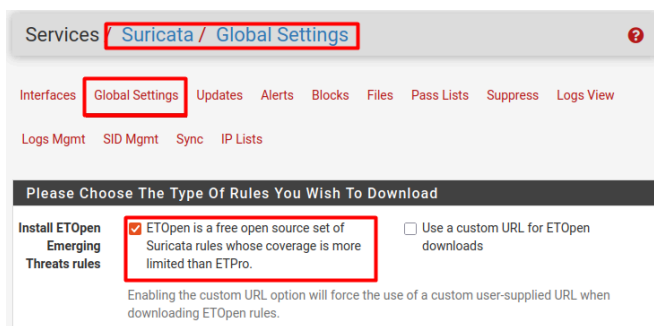
4. Definició de Polítiques de Seguretat

Un cop tenim Suricata instal·lat a pfSense, el sistema per defecte No farà res fins que no li donem un diccionari amb les amenaces que ha de detectar i li diguem com ha de reaccionar quan en trobi una. Aquesta fase de configuració és el punt més important del projecte.

4.1. Selecció de signatures

Els sistemes de detecció funcionen mitjançant "signatures" (regles predefinides que descriuen com és un atac). A pfSense, dins del menú Global Settings de Suricata, hem hagut de triar d'on traurem aquestes regles.

Hem configurat el sistema perquè utilitzi les llistes gratuïtes i de codi obert **Emerging Threats (ET) Open**. Aquestes signatures es mantenen actualitzades per la comunitat de ciberseguretat i són essencials per al nostre laboratori, ja que contenen els patrons exactes per detectar trànsit associat a xarxes zombi (botnets), programari maliciós (malware), escanejors de ports d'atacants i intents d'explotar vulnerabilitats conegudes (exploits).



4.2. Actualització del motor de detecció

De poc serveix tenir les millors regles si no estan al dia (cada dia surten atacs nous). Un cop seleccionada la font "ET Open", hem anat a la pestanya d'actualitzacions (Updates) i hem forçat el procés de descàrrega manual ("Update"). Això fa que pfSense es connecti als servidors oficials, es descarregui les darreres definicions d'amenaces i les apliqui al motor de Suricata. A la vida real, això es programa perquè es faci automàticament de matinada.

Services / Suricata / Updates

Interfaces Global Settings Updates Alerts Blocks Files Pass Lists Suppress Logs View

Logs Mgmt SID Mgmt Sync IP Lists

INSTALLED RULE SET MD5 SIGNATURES

Rule Set Name/Publisher	MD5 Signature Hash	MD5 Signature Date
Emerging Threats Open Rules	1819d273fbee3629b129a81f4a787f00	Monday, 16-Mar-26 19:35:00 UTC
Snort Subscriber Rules	Not Enabled	Not Enabled
Snort GPLv2 Community Rules	Not Enabled	Not Enabled
Feodo Tracker Botnet C2 IP Rules	Not Enabled	Not Enabled
ABUSE.ch SSL Blacklist Rules	Not Enabled	Not Enabled

UPDATE YOUR RULE SET

Last Update: Mar-16 2026 19:35
Result: success

Update Force

4.3. Implementació de la Instància de Vigilància

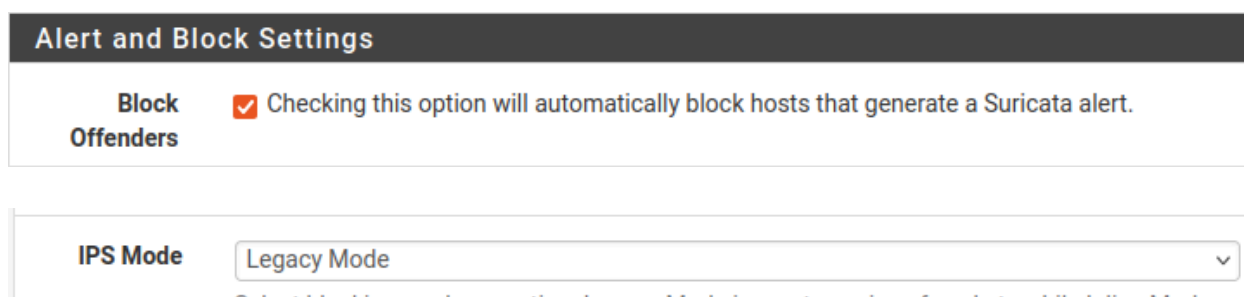
Ara que el sistema ja sap què ha de buscar, li hem de dir on ho ha de buscar. A l'hora de desplegar un sistema IDS/IPS en un router com pfSense, la decisió de quines interfícies (zones de la xarxa) hem d'escoltar és vital per a la seguretat. Hem activat Suricata a les dues targetes de xarxa amb objectius molt diferents:

Interface Settings Overview					
Interface	Suricata Status	Pattern Match	Blocking Mode	Description	Actions
☐ LAN (em1)		AUTO	LEGACY MODE	LAN	
☐ WAN (em0)		AUTO	INLINE IPS	WAN	

- **Monitorització a la WAN (Internet):** Aquesta interfície actua com el nostre escut exterior. Escoltar la WAN ens permet analitzar tot el trànsit que ve d'Internet abans que

entri a la xarxa. Aquí és on detectem i bloquegem d'arrel els atacs directes (escanejos massius de ports cercant forats, intents de força bruta o bots automàtics). És el nostre sistema d'alerta primerenca contra allò que ve de fora.

- **Monitorització a la LAN (Xarxa Local):** Vigilar la LAN és fins i tot més important. Ens permet controlar de forma estricta què passa "de portes endins". Si un usuari de la nostra empresa es baixa un arxiu amb virus o el seu ordinador s'infecta, aquest equip intentarà connectar-se amb l'atacant a través d'Internet (el que s'anomena connexió C&C). Tenir Suricata a la LAN detectarà aquesta sortida de dades anòmla o qualsevol atac entre els mateixos equips de la nostra xarxa interna.



4.4. Configuració de polítiques per a diferents zones de la xarxa

Perquè el nostre sistema no sigui un simple detecto, hem de configurar com respondrà als atacs. Per a aquest projecte, hem decidit configurar tant la WAN com la LAN utilitzant el "Legacy Mode", ja que garanteix la màxima estabilitat i compatibilitat amb el tallafocs natiu de pfSense.

El funcionament del Legacy Mode:

Aquest mode de bloqueig tradicional és molt intel·ligent i eficaç. Funciona de la següent manera per a totes dues targetes:

- Suricata analitza el trànsit en temps real.
- Si una regla detecta trànsit perillós, el motor genera una alerta i extreu automàticament l'adreça IP de l'atacant.
- Envia aquesta IP de forma instantània a una taula interna del tallafocs de pfSense (pf table).

- En aquell mateix segon, pfSense talla qualsevol comunicació present i futura amb aquella IP. Així, el sistema s'encarrega d'aturar l'atac en temps real sense necessitat que l'administrador intervingui.

Interface Settings Overview					
Interface	Suricata Status	Pattern Match	Blocking Mode	Description	Actions
 LAN (em1)		AUTO	LEGACY MODE	LAN	 
 WAN (em0)		AUTO	LEGACY MODE	WAN	 

Ajustament de l'Acceleració per Maquinari (Hardware Offloading)

Perquè el mode IPS funcioni bé, pugui tallar els paquets correctament i el sistema no ens mostri missatges d'error, hem hagut de fer un ajustament imprescindible a la configuració base de pfSense.

Dins del menú principal (System > Advanced > Networking), hem hagut de **marcar (activar) la casella anomenada "Disable hardware checksum offload"**.

Network Interfaces	
Hardware Checksum Offloading	☒ Disable hardware checksum offload Checking this option will disable hardware checksum offloading. Checksum offloading is broken in some hardware. This will take effect after the next reboot.
Hardware TCP Segmentation Offloading	☒ Disable hardware TCP segmentation offload Checking this option will disable hardware TCP segmentation offloading. This may impact performance with some specific NICs.
Hardware Large Receive Offloading	☒ Disable hardware large receive offload Checking this option will disable hardware large receive offloading. This may impact performance with some specific NICs. This will take effect after the next reboot.

El resultat és que **desactivem** aquesta funció d'acceleració de la targeta de xarxa. Això obliga a que tot el trànsit passi directament pel processador central (CPU) de la màquina, permetent a Suricata inspeccionar els paquets a fons i extreure les IPs correctament abans que la targeta de xarxa actuï pel seu compte.

Ajustament de les Accions (Alert vs Drop)

Un error molt comú és pensar que, un cop descarregat el paquet de regles (les signatures d'ET Open), el sistema ja ho analitza i ho bloqueja tot per defecte. Això no va així. Hem d'anar a la pestanya Categories i dir-li a Suricata quines llistes d'amenaques ha de vigilar. Activar-les totes de cop saturaria la memòria RAM del sistema, així que hem seleccionat de forma estratègica les categories més crítiques per al nostre entorn:

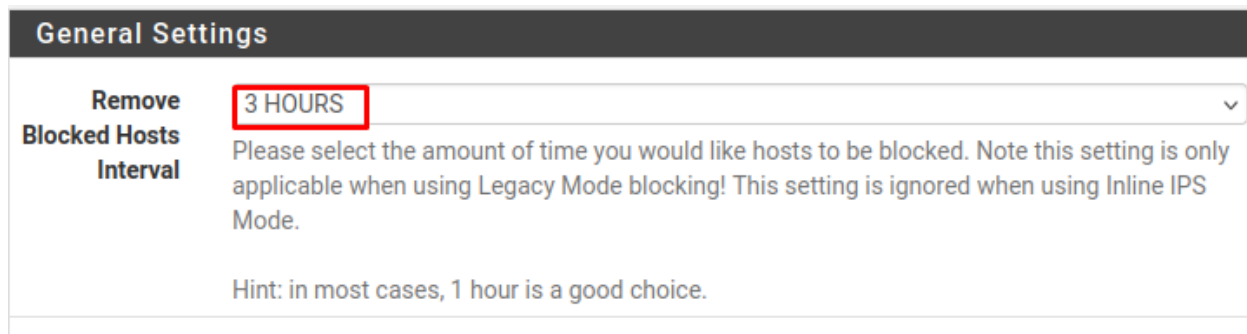
- **emerging-scan.rules:** Fonamental per detectar escanejos massius de ports (com atacs amb Nmap). Això ens permet bloquejar un atacant durant la fase de reconeixement, abans i tot que trobi vulnerabilitats a la nostra xarxa.
- **emerging-malware.rules / emerging-botcc.rules:** Vitales per detectar codi maliciós i evitar que un equip infectat de la nostra LAN es comuniqui amb un servidor extern de Comandament i Control (C&C).
- **emerging-web_server.rules / emerging-exploit.rules:** Protecció essencial contra atacs d'injecció o vulnerabilitats conegudes, molt útil si tenim serveis publicats a Internet.

4.5. Establiment de mecanismes de resposta a incidents

Perquè el nostre sistema no sigui un simple detector passiu (IDS) i passi a ser actiu (IPS), s'han configurat els següents mecanismes de resposta ràpida:

A) Bloqueig Automàtic d'Atacants

Com es pot observar a la configuració de la instància LAN, hem marcat l'opció Block Offenders. Això indica a Suricata que, quan una signatura detecti trànsit maliciós, extregui la IP de l'atacant i l'envii automàticament a una taula de bloqueig del firewall de pfSense (pf table). D'aquesta manera, es talla la comunicació en temps real.



The screenshot shows the 'General Settings' page in pfSense. On the left, under the 'Firewall' tab, the 'Remove Blocked Hosts Interval' is set to '3 HOURS'. A red box highlights the '3 HOURS' dropdown menu. Below the dropdown, there is a note: 'Please select the amount of time you would like hosts to be blocked. Note this setting is only applicable when using Legacy Mode blocking! This setting is ignored when using Inline IPS Mode.' and a hint: 'Hint: in most cases, 1 hour is a good choice.'

B) Prevenció de Bloquejos Propis

Un risc molt important en habilitar el mode IPS és el "self-lockout" o autobloqueig. Si cometem un error o es genera un fals positiu, Suricata podria bloquejar la IP de gestió de l'administrador o el propi router, deixant-nos sense accés.

Per evitar-ho, hem creat una Pass List (Llista Blanca) on hem definit les IPs de confiança que el sistema mai ha de bloquejar.

General Information

Name

The list name may only consist of the characters 'a-z, A-Z, 0-9 and _'.

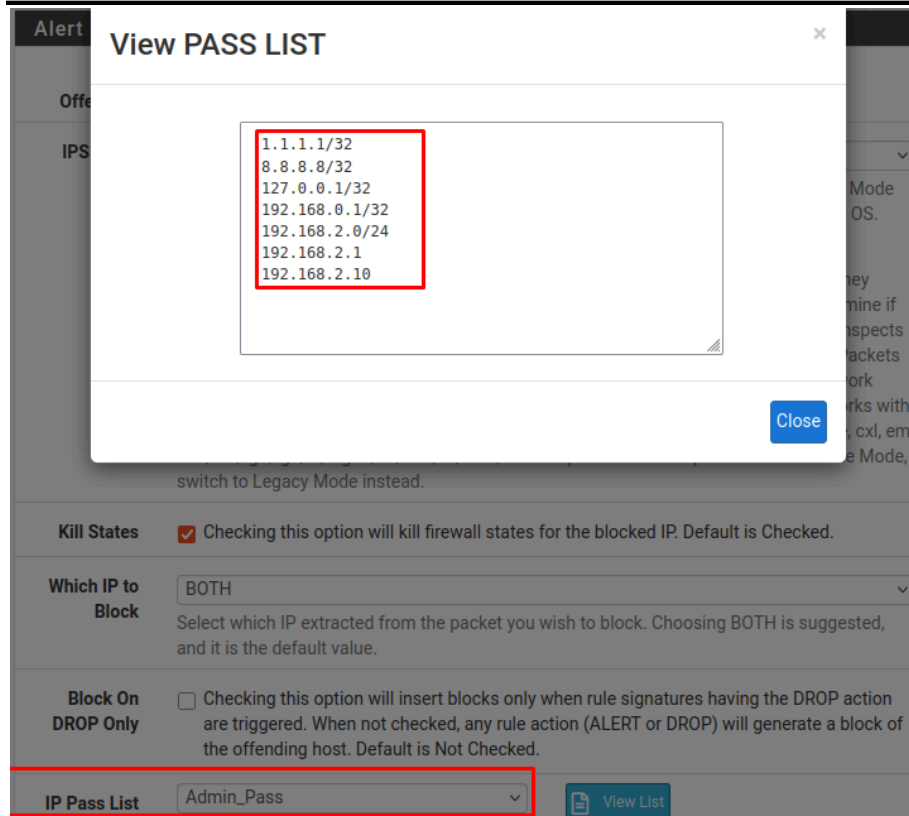
Custom IP Addresses and Configured Firewall Aliases

Hint Enter as many IP addresses or alias names as desired. Enter ONLY an IP address, IP subnet or alias name! Do NOT enter a FQDN (fully qualified domain name) directly! To use a FQDN, first create the necessary firewall alias, and then provide the alias name here. FQDN aliases are periodically re-resolved and updated by the firewall. You can also provide an IP subnet with a proper netmask of the form network/mask such as 1.2.3.0/24.

IP or Alias	192.168.2.1	 Delete
IP or Alias	192.168.2.10	 Delete

Com es pot observar a la imatge, dins de la configuració de la instància de la LAN, s'ha assignat la llista blanca creada prèviament anomenada admin_pass a l'apartat IP Pass List. En fer clic a "View List", el sistema ens confirma de manera visual totes les adreces IP que queden totalment protegides contra autobloquejos per part del motor IPS.

Aquesta llista en concret inclou els servidors DNS públics com l'1.1.1.1 i el 8.8.8.8, la xarxa local sencera i, de forma molt específica, les adreces de la porta d'enllaç del router 192.168.2.1 i de la nostra màquina d'administració 192.168.2.1). D'aquesta manera, garantim que mai perdrem l'accés a la gestió del tallafocs encara que es dispari un fals positiu.



4.6. Configuració avançada del sistema de Logs (EVE JSON)

Per defecte, Suricata a pfSense genera alertes en un format de text pla bàsic (el clàssic arxiu fast.log). No obstant això, per a aquest laboratori hem decidit innovar i fer un salt cap a una arquitectura en format EVE JSON (Extensible Event Format).

Generació de logs detallats i moderns:

L'activació del format EVE JSON transforma cada esdeveniment de la xarxa en un objecte de dades estructurat. Això no només ens permet registrar les alertes d'intrusió, sinó que també habilita la monitorització,

Integració i centralització:

Aquest format EVE JSON és l'estàndard que ens permetria, en una fase posterior o en un entorn de producció real, recollir tots aquests registres mitjançant un agent i integrar-los directament amb el sistema de monitorització Zabbix que ja tenim muntat. D'aquesta manera, centralitzem les alertes.

EVE Output Settings

EVE JSON Log ☒ Suricata will output selected info in JSON format to a single file or to syslog. Default is Not Checked.

EVE Output Type FILE
Select EVE log output destination. Choosing FILE is suggested and is the default value. "Redis" is used for output to a Redis server, and the UNIX Socket options output to a user-created socket.

Resultat de la generació de Logs (EVE JSON)

Un cop activat el format, hem executat la comanda **tail -n 1 /var/log/suricata/suricata_em053473/eve.json** des de la consola de pfSense per extreure l'últim registre generat pel motor de Suricata.

Tot i que el sistema ho desa en una sola línia per estalviar espai, a continuació es mostra el mateix registre estructurat per facilitar-ne l'anàlisi tècnic:

```
1  {
2    "timestamp": "2026-04-23T17:19:50.011218+0000",
3    "flow_id": 1717929353507837,
4    "in_iface": "em0",
5    "event_type": "dns",
6    "src_ip": "192.168.0.24",
7    "src_port": 11818,
8    "dest_ip": "192.5.5.241",
9    "dest_port": 53,
10   "proto": "UDP",
11   "pkt_src": "wire/pcap",
12   "dns": {
13     "version": 2,
14     "type": "answer",
15     "id": 9431,
16     "flags": "8492",
17     "qr": true,
18     "aa": true,
19     "ra": true,
20     "opcode": 0,
21     "rrname": "",
22     "rrtype": "NS",
23     "rcode": "SERVFAIL"
24   }
25 }
```

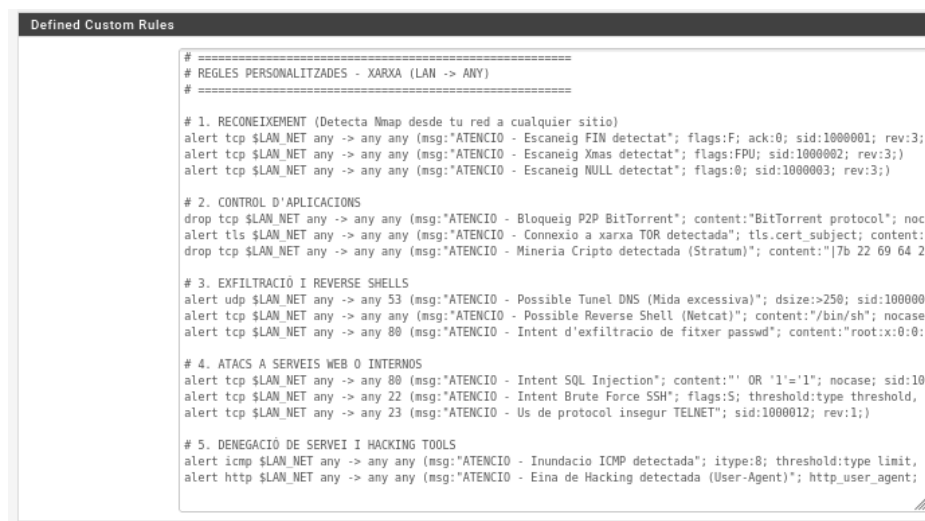
Com es pot observar, el format EVE JSON és molt superior al text pla clàssic. En aquest cas concret, Suricata ha registrat un esdeveniment de tipus **dns**. No només captura les dades de capa 3 i 4 (**IP d'origen 192.168.0.24 i port de destí 53**), sinó que realitza una inspecció profunda i extreu les dades de la capa 7 Aplicació, detectant que es tracta d'una resposta DNS que ha fallat ("**rcode**": "**SERVFAIL**").

5. Simulació d'Atacs i Resposta

En aquesta fase del projecte, s'ha passat de la configuració genèrica a la implementació de polítiques de seguretat personalitzades. L'objectiu és demostrar la capacitat de Suricata per inspeccionar el trànsit intern de la LAN i reaccionar davant d'amenaques específiques llançades des d'una màquina d'auditoria (Kali Linux).

5.1. Implementació de Regles Personalitzades

Tot i que Suricata utilitza les llistes de Emerging Threats, hem dissenyat un conjunt de regles pròpies per detectar comportaments anòmals dins de la nostra xarxa local. S'ha utilitzat l'adreça de destinació any per permetre que el sistema detecti no només atacs al tallafocs, sinó també el moviment lateral entre equips de la LAN.



```
Defined Custom Rules

# =====
# REGLES PERSONALITZADES - XARXA (LAN -> ANY)
# =====

# 1. RECONeixEMENT (Detecta Nmap desde tu red a cualquier sitio)
alert tcp $LAN_NET any -> any any (msg:"ATENCIÓN - Escaneig FIN detectat"; flags:F; ack:0; sid:1000001; rev:3;)
alert tcp $LAN_NET any -> any any (msg:"ATENCIÓN - Escaneig Xmas detectat"; flags:FPU; sid:1000002; rev:3;)
alert tcp $LAN_NET any -> any any (msg:"ATENCIÓN - Escaneig NULL detectat"; flags:0; sid:1000003; rev:3;)

# 2. CONTROL D'APLICACIONS
drop tcp $LAN_NET any -> any any (msg:"ATENCIÓN - Bloqueig P2P BitTorrent"; content:"BitTorrent protocol"; nocase; sid:1000004; rev:1;)
alert tcp $LAN_NET any -> any any (msg:"ATENCIÓN - Connexió a xarxa TOR detectada"; tls.cert.subject; content:"*.onion"; nocase; sid:1000005; rev:1;)
drop tcp $LAN_NET any -> any any (msg:"ATENCIÓN - Minería Cripto detectada (Stratum)"; content:"[7b 22 69 64 22]"; nocase; sid:1000006; rev:1;)

# 3. EXFILTRACIÓ I REVERSE SHELLS
alert udp $LAN_NET any -> any 53 (msg:"ATENCIÓN - Possible Tunnel DNS (Mida excessiva)"; dsize:>250; sid:1000007; rev:1;)
alert tcp $LAN_NET any -> any any (msg:"ATENCIÓN - Possible Reverse Shell (Netcat)"; content:"/bin/sh"; nocase; sid:1000008; rev:1;)
alert tcp $LAN_NET any -> any 80 (msg:"ATENCIÓN - Intent d'exfiltració de fitxer passwd"; content:"root:x:0:0:0:0:0:0"; nocase; sid:1000009; rev:1;)

# 4. ATACS A SERVEIS WEB O INTERNOS
alert tcp $LAN_NET any -> any 80 (msg:"ATENCIÓN - Intent SQL Injection"; content:"' OR '1'='1'"; nocase; sid:1000010; rev:1;)
alert tcp $LAN_NET any -> any 22 (msg:"ATENCIÓN - Intent Brute Force SSH"; flags:S; threshold:type threshold, count; sid:1000011; rev:1;)
alert tcp $LAN_NET any -> any 23 (msg:"ATENCIÓN - Ús de protocol insegur TELNET"; sid:1000012; rev:1;)

# 5. DENEGACIÓ DE SERVEI I HACKING TOOLS
alert icmp $LAN_NET any -> any any (msg:"ATENCIÓN - Inundació ICMP detectada"; itype:8; threshold:type limit, count; sid:1000013; rev:1;)
alert http $LAN_NET any -> any any (msg:"ATENCIÓN - Eina de Hacking detectada (User-Agent)"; http.user_agent; content:"sqlmap"; nocase; sid:1000014; rev:1;)
```

Anàlisi General de les Regles Implementades

Les regles configurades es divideixen en tres pilars fonamentals de la ciberseguretat:

1. Detecció de Reconeixement (Anti-Scanning):

- **Regles: Escaneig FIN, Xmas i NULL.**
- **Per què les fem servir:** Són tècniques clàssiques de **Nmap** que intenten esquivar firewalls simples. En una xarxa corporativa, cap aplicació legítima genera paquets TCP sense "flags" o amb combinacions invàlides. Detectar-les ens permet identificar un atacant (com la nostra màquina Kali) en la fase inicial de sondeig.

2. Control de Polítiques i Recursos (Compliance):

- **Regles: Bloqueig P2P BitTorrent i Minería Cripto.**
- **Per què les fem servir:** Aquestes regles no busquen només "hackers", sinó el mal ús dels recursos de l'empresa. El bloqueig de mineria de criptomonedes (protocol Stratum) evita el consum excessiu de CPU i electricitat, mentre que el

bloqueig de P2P protegeix l'amplada de banda i evita possibles problemes legals per descàrregues.

3. Seguretat a Nivell d'Aplicació i Exfiltració:

- **Regles: SQL Injection i Intent d'exfiltració de fitxer passwd.**
- **Per què les fem servir:** Demostren la potència de la **Inspecció Profunda de Paquets (DPI)**. Suricata no només mira el port 80 (HTTP), sinó que llegeix el contingut del trànsit. Si detecta patrons com ' OR '1'='1 o cadenes de text típiques de fitxers de sistema (com root:x:0:0:), genera una alerta immediata abans que les dades surtin de la xarxa.

Lògica de Configuració: L'ús de any

Com es pot observar a la captura, hem definit el destí de les regles com any. Aquesta és una decisió de disseny clau:

- **Objectiu:** Monitoritzar el **moviment lateral**. Si un equip compromès a la LAN intenta atacar un altre ordinador de la mateixa xarxa, Suricata ho detectarà. Si haguéssim limitat el destí només a la IP del firewall, estaríem cecs davant d'atacs interns entre hosts.

5.2. Pentesting de la xarxa LAN

Un cop configurades les regles personalitzades en mode any -> any, hem procedit a realitzar una auditoria des de la màquina **Kali Linux** per verificar que el motor Suricata respon correctament davant d'atacs reals.

A la següent captura de pantalla es mostra el **Tauler d'Alertes** (Services > Suricata > Alerts), on podem confirmar l'èxit de les proves realitzades:

Prova 1: Escaneig de Ports (Nmap NULL Scan)

Explicació de la comanda: Aquesta comanda envia paquets TCP sense cap tipus de "flag" o bandera activada. És una tècnica de reconeixement que serveix per intentar descobrir ports oberts sense aixecar sospites en tallafocs senzills.

INS Sa Palomera

ASIX – Projecte Final de Curs 2025-2026

Grup: Izan Ruiz · Youssef Fouad · Adrià Rodríguez

Last 250 Alert Entries. (Most recent entries are listed first)										
Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
04/10/2026 15:41:22		3	TCP	Not Assigned	192.168.10.105	53897	192.168.10.1	311	1:1000003	ATENCIO - Escaneig NULL detectat
04/10/2026 15:41:22		3	TCP	Not Assigned	192.168.10.105	53897	192.168.10.1	9071	1:1000003	ATENCIO - Escaneig NULL detectat
04/10/2026 15:41:22		3	TCP	Not Assigned	192.168.10.105	53897	192.168.10.1	6547	1:1000003	ATENCIO - Escaneig NULL detectat
04/10/2026 15:41:22		3	TCP	Not Assigned	192.168.10.105	53899	192.168.10.1	1503	1:1000003	ATENCIO - Escaneig NULL detectat
04/10/2026 15:41:22		3	TCP	Not Assigned	192.168.10.105	53899	192.168.10.1	3814	1:1000003	ATENCIO - Escaneig NULL detectat
04/10/2026 15:41:21		3	TCP	Not Assigned	192.168.10.105	53897	192.168.10.1	8194	1:1000003	ATENCIO - Escaneig NULL detectat
04/10/2026 15:41:21		3	TCP	Not Assigned	192.168.10.105	53897	192.168.10.1	44442	1:1000003	ATENCIO - Escaneig NULL detectat

Prova 2: Escaneig de vulnerabilitats amb Nikto

Comanda llançada al terminal de Kali nikto -h 192.168.10.1

```
(kali㉿kali)-[~]
$ nikto -h 192.168.10.1
- Nikto v2.6.0

+ Your Nikto installation is out of date.
+ Target IP:      192.168.10.1
+ Target Hostname: 192.168.10.1
+ Target Port:    80
+ Platform:       Unknown
+ Start Time:     2026-04-10 10:31:17 (GMT-4)

+ Server: nginx
```

Last 1000 Alert Entries. (Most recent entries are listed first)										
Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
04/10/2026 17:24:19		3	TCP	Generic Protocol Command Decode	192.168.10.105	59458	192.168.10.1	80	1:2221015	SURICATA HTTP Host header ambiguous
04/10/2026 17:24:12		3	TCP	Generic Protocol Command Decode	192.168.10.105	37360	192.168.10.1	80	1:2260002	SURICATA Applayer Detect protocol only one direction
04/10/2026 17:24:12		3	TCP	Generic Protocol Command Decode	192.168.10.105	37320	192.168.10.1	80	1:2221028	SURICATA HTTP Host header invalid
04/10/2026 17:24:17		3	TCP	Generic Protocol Command Decode	192.168.10.105	37392	192.168.10.1	80	1:2260002	SURICATA Applayer Detect protocol only one direction
04/10/2026 17:24:12		3	TCP	Generic Protocol Command Decode	192.168.10.105	37332	192.168.10.1	80	1:2260002	SURICATA Applayer Detect protocol only one direction

Explicació de la comanda: Nikto és una eina que realitza milers de peticions automàtiques per trobar vulnerabilitats. Com que és una eina d'escaneig massiu, genera molt de "soroll" a la xarxa.

Anàlisi del resultat (Captura pfSense): Com es pot observar a la captura d'alertes, Suricata reacciona immediatament detectant **anomalies en el protocol HTTP**. Apareixen alertes de tipus Generic Protocol Command Decode:

- **HTTP Host header ambiguous:** Nikto intenta manipular les capçaleres per confondre el servidor.
- **Applayer Detect protocol only one direction:** Detecta un flux de dades anòmal que no segueix el comportament d'una navegació web normal.
- **HTTP Host header invalid:** Identifica peticions mal estructurades creades per l'escàner.

Prova 3: Atac de Força Bruta contra SSH (Hydra)

```
Welcome to the Hydra Wizard
```

```
Enter the service to attack (eg: ftp, ssh, http-post-form): ssh
Enter the target to attack (or filename with targets): 192.168.10.1
Enter a username to test or a filename: admin
Enter a password to test or a filename: admin
```

```
If you want to add module options, enter them here (or leave empty):
```

```
The following command will be executed now:
```

```
hydra -l admin -p admin -u 192.168.10.1 ssh
```

```
Do you want to run the command now? [Y/n] y
```

```
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).
```

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-10 10:
36:14
```

```
[WARNING] Many SSH configurations limit the number of parallel tasks, it is r
ecommended to reduce the tasks: use -t 4
```

```
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try
per task
```

```
[DATA] attacking ssh://192.168.10.1:22/
```

```
[ERROR] could not connect to ssh://192.168.10.1:22 - Timeout connecting to 19
2.168.10.1
```

Explicació de la comanda: Utilitzem Hydra per intentar accedir al servei SSH del pfSense. Tot i que posem una contrasenya fixa, Hydra realitza múltiples intents de connexió ràpids per segon.

Explicació del resultat: Com es veu a la captura de pfSense, Suricata ha disparat l'alerta amb el missatge "**ATENCIO - Intent Brute Force SSH**". Això confirma que la regla amb "threshold" funciona: el sistema ha identificat que el Kali estava obrint massa connexions TCP (flags SYN) en un interval de temps molt curt, una activitat clarament maliciosa.

Last 1000 Alert Entries. (Most recent entries are listed first)

Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
04/10/2026 18:03:32		3	TCP	Not Assigned	192.168.10.105	60266	192.168.10.1	22	1:1000011	ATENCIO - Intent Brute Force SSH
04/10/2026 17:56:20		3	TCP	Not Assigned	192.168.10.105	41196	192.168.10.1	22	1:1000011	ATENCIO - Intent Brute Force SSH

Comanda llançada al terminal de Kali: dirb http://192.168.10.1 /usr/share/dirb/wordlists/common.txt

```

dirb https://secure_dirb/ (Simple test with SSL)
(kali㉿kali)-[~]
$ dirb http://192.168.10.1 /usr/share/dirb/wordlists/common.txt
+-----+-----+
| HTTP RTT | ADDRESS |
+-----+-----+
| 1.0000000 | se.home.arpa (192.168.10.1) |
+-----+-----+

DIRB v2.22
By The Dark Raver
Detection performed. Please report any incorrect results to dirb@darkraver.com or https://github.com/darkraver/dirb/.
Nmap done: 1 IP address (1 host up) scanned in 26.34 seconds
START_TIME: Fri Apr 10 10:41:43 2026
URL_BASE: http://192.168.10.1/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

```

Explicació de la comanda: S'utilitza l'eina DIRB v2.22 per realitzar un atac de tipus diccionari contra el servidor web del pfSense. L'objectiu és localitzar directoris o fitxers ocults mitjançant una llista de paraules clau (common.txt). Aquest procés genera una ràfega de peticions HTTP GET en un temps molt reduït.

Explicació del resultat: En executar la comanda el panell d'alertes de Suricata comença a registrar activitat immediatament. Curiosament, el motor d'intel·ligència de Emerging Threats identifica el patró d'atac com a SCAN Possible Nmap User-Agent Observed.

Això passa perquè:

Signatures compartides: Moltes eines de reconeixement web com DIRB utilitzen capçaleres similars a les de Nmap per defecte.

Detecció de comportament: Suricata detecta el comportament de l'escàner d'enumeració i el classifica dins de la categoria d'alertes de sondeig.

Last 1000 Alert Entries. (Most recent entries are listed first)										
Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
04/10/2026 18:34:57		1	TCP	Web Application Attack	192.168.10.105 	40592	192.168.10.1 	80	1:2024364  	ET SCAN Possible Nmap User-Agent Observed
04/10/2026 18:34:57		1	TCP	Web Application Attack	192.168.10.105 	40576	192.168.10.1 	80	1:2024364  	ET SCAN Possible Nmap User-Agent Observed
04/10/2026 18:34:56		1	TCP	Web Application Attack	192.168.10.105 	40566	192.168.10.1 	80	1:2024364  	ET SCAN Possible Nmap User-Agent Observed
04/10/2026 18:34:56		1	TCP	Web Application Attack	192.168.10.105 	40564	192.168.10.1 	80	1:2024364  	ET SCAN Possible Nmap User-Agent Observed
04/10/2026 18:34:56		1	TCP	Web Application Attack	192.168.10.105 	40548	192.168.10.1 	80	1:2024364  	ET SCAN Possible Nmap User-Agent Observed
04/10/2026 18:34:56		1	TCP	Web Application Attack	192.168.10.105 	40540	192.168.10.1 	80	1:2024364  	ET SCAN Possible Nmap User-Agent Observed

Prova 5: Atac de Denegació de Servei (DoS) amb hping3

Eina utilitzada: hping3 (Eina de Kali Linux per a la generació i anàlisi de paquets TCP/IP).

Comanda llançada al terminal de Kali:

```
(kali@kali)-[~]
$ sudo hping3 -S --flood -p 80 192.168.10.1
[sudo] password for kali:
HPING 192.168.10.1 (eth0 192.168.10.1): S set, 40 headers + 0 data bytes
hping in flood mode, no replies will be shown
^C
— 192.168.10.1 hping statistic —
119287 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms
```

Explicació de la comanda: S'ha executat un atac de tipus SYN Flood. El paràmetre --flood indica que s'han d'enviar paquets el més ràpid possible sense esperar resposta. Com es veu a la captura del terminal, s'han transmès 119.287 paquets en pocs segons cap al port 80 del firewall.

Anàlisi del resultat en pfSense: Tants de paquets ha provocat que el motor Suricata identifiqui una saturació en el flux de dades. Les alertes registrades són de tipus SURICATA STREAM 3way handshake SYNACK with wrong ack.

Al rebre milers de peticions de connexió (SYN) per segon, el sistema intenta respondre, però el flux és tan massiu que les seqüències de reconeixement (ACK) es tornen invàlides o arriben fora d'ordre.

Last 1000 Alert Entries. (Most recent entries are listed first)										
Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
04/10/2026 19:39:27		3	TCP	Generic Protocol Command Decode	192.168.10.1  	80	192.168.10.105  	49221	1:2210007  	SURICATA STREAM 3way handshake SYNACK with wrong ack
04/10/2026 19:39:27		3	TCP	Generic Protocol Command Decode	192.168.10.1  	80	192.168.10.105  	49186	1:2210007  	SURICATA STREAM 3way handshake SYNACK with wrong ack
04/10/2026 19:39:27		3	TCP	Generic Protocol Command Decode	192.168.10.1  	80	192.168.10.105  	49177	1:2210007  	SURICATA STREAM 3way handshake SYNACK with wrong ack
04/10/2026 19:39:27		3	TCP	Generic Protocol Command Decode	192.168.10.1  	80	192.168.10.105  	49059	1:2210007  	SURICATA STREAM 3way handshake SYNACK with wrong ack

Prova 6: Seguretat en la descàrrega de programari i control de trànsit

Acció realitzada: Intent de descàrrega i instal·lació d'eines externes des de la terminal de Kali Linux mitjançant la comanda apt update i apt install.

Context de la prova: En un entorn corporatiu real, la descàrrega de certes eines de tercers o el trànsit massiu cap a repositoris externs pot ser un risc (programari no autoritzat, malware, etc.). En aquesta prova, hem intentat baixar una eina de xarxa poc habitual.

Com es pot observar a la captura del terminal la descàrrega ha quedat totalment interrompuda. El sistema ha retornat errors de tipus Connection timed out i Failed to fetch. Això ens indica que el firewall ha tallat la comunicació enmig del procés.

```
- connect (101: Network is unreachable) Cannot initiate the connection to kal
i.download:80 (2606:4700::6811:feef). - connect (101: Network is unreachable)
Could not connect to kali.download:80 (104.17.253.239), connection timed out
Could not connect to kali.download:80 (104.17.254.239), connection timed out
[IP: 104.17.253.239 80]
Cannot initiate the connection to kali.download:80 (2606:4700::6811:fdef).
- connect (101: Network is unreachable) Cannot initiate the connection to kal
i.download:80 (2606:4700::6811:feef). - connect (101: Network is unreachable)
[IP: 104.17.253.239 80]
Ign:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb)
Err:3 http://http.kali.org/kali kali-rolling/main amd64 Contents (deb)
Connection timed out [IP: 104.17.254.239 80]
Connection timed out [IP: 104.17.253.239 80]
Cannot initiate the connection to kali.download:80 (2606:4700::6811:fdef).
- connect (101: Network is unreachable) Cannot initiate the connection to kal
i.download:80 (2606:4700::6811:feef). - connect (101: Network is unreachable)
Could not connect to kali.download:80 (104.17.253.239), connection timed out
Could not connect to kali.download:80 (104.17.254.239), connection timed out
[IP: 104.17.253.239 80]
Cannot initiate the connection to kali.download:80 (2606:4700::6811:fdef).
- connect (101: Network is unreachable) Cannot initiate the connection to kal
i.download:80 (2606:4700::6811:feef). - connect (101: Network is unreachable)
[IP: 104.17.253.239 80]
404 Not Found [IP: 54.39.128.230 80]
Fetched 22.6 MB in 1min 50s (205 kB/s)
Error: Failed to fetch http://http.kali.org/kali/dists/kali-rolling/main/Cont
ents-amd64 404 Not Found [IP: 54.39.128.230 80]
Error: Some index files failed to download. They have been ignored, or old on
```

Explicació: Al revisar la pestanya de **Blocked Hosts**, veiem que el Suricata ha llistat les IPs externes dels servidors de descàrrega com a amenaces.

- El motiu ha estat **SURICATA STREAM excessive retransmissions**.
- Què significa això? El firewall ha detectat que el flux de dades de la descàrrega d'aquestes eines no era net. En detectar massa retransmissions o un comportament de xarxa inestable, l'IDS ha decidit que el trànsit era sospitós de ser un atac de denegació de servei (DoS) o una intrusió, i ha passat a mode **IPS (Intrusion Prevention System)** bloquejant la font automàticament.

INS Sa Palomera

ASIX – Projecte Final de Curs 2025-2026

Grup: Izan Ruiz · Youssef Fouad · Adrià Rodríguez

Last 500 Hosts Blocked by Suricata				
Note: Only blocked IP addresses from Legacy Mode interfaces are shown! For inline IPS mode interfaces, dropped IP addresses are highlighted on the ALERTS tab.				
Blocked IP	Block Date/Time	Block Alert Description	Block Rule GID:SID	Remove Block
104.17.254.239  	04/10/2026 21:37:30	SURICATA STREAM excessive retransmissions	1:2210054	
104.17.253.239  	04/10/2026 21:40:10	SURICATA STREAM excessive retransmissions	1:2210054	
172.217.17.46  	04/10/2026 16:48:17	SURICATA QUIC failed decrypt	1:2231000	
3 host IP addresses are currently being blocked.				

Després del bloqueig anterior, s'ha intentat descarregar i instal·lar un programari reconegut i segur com Google Chrome.

A diferència de la prova anterior amb eines de "hacking" o repositoris no reconeguts, la descàrrega de Google Chrome s'ha completat sense cap interrupció. El terminal no ha mostrat errors de connexió i el fitxer s'ha baixat correctament.

Prova 7: Detecció de Protocols Insegurs (Telnet)

Acció realitzada: Intent de connexió des de la màquina Kali (192.168.10.105) cap a la interfície de gestió del pfSense (192.168.10.1) utilitzant el protocol Telnet (port 23).

Explicació: Telnet és un protocol antic que transmet tota la informació, incloent usuaris i contrasenyes, en text pla (sense xifrar). En aquesta prova volem verificar si les regles generals de Suricata estan configurades per detectar l'ús de protocols insegurs que posen en risc la confidencialitat de la xarxa.

Last 1000 Alert Entries. (Most recent entries are listed first)										
Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
04/11/2026 04:11:09		3	TCP	Not Assigned	192.168.10.105  	50522	192.168.10.1  	23	1:1000012  	ATENCIO - Us de protocol insegur TELNET
04/11/2026 04:07:19		3	TCP	Not Assigned	192.168.10.105  	50522	192.168.10.1  	23	1:1000012  	ATENCIO - Us de protocol insegur TELNET
04/11/2026 04:06:03		3	TCP	Not Assigned	192.168.10.105  	50522	192.168.10.1  	23	1:1000012  	ATENCIO - Us de protocol insegur TELNET
04/11/2026 04:03:56		3	TCP	Not Assigned	192.168.10.105  	50522	192.168.10.1  	23	1:1000012  	ATENCIO - Us de protocol insegur TELNET
04/11/2026 04:02:07		1	TCP	Web Application Attack	192.168.10.105  	52008	192.168.10.1  	80	1:2024364  	ET SCAN Possible Nmap User-Agent Observed

Prova 8: Detecció de protocols i trànsit anòmal

Acció realitzada: Enviament de paquets de control (ICMP/Ping) amb una mida de paquet superior a l'estàndard i de manera continuada des del Kali (192.168.10.105) cap al pfSense (192.168.10.1).

Comanda utilitzada: ping -s 2000 192.168.10.1 (això envia paquets de 2000 bytes, que és una anomalia per a un ping normal).

Explicació: Moltes regles generals de seguretat bloquegen o alerten sobre paquets ICMP de gran tamany, ja que poden ser utilitzats per realitzar atacs de fragmentació o per amagar informació dins dels paquets (ICMP Tunneling). Aquesta prova verifica si el motor Suricata inspecciona fins i tot els protocols més bàsics de la xarxa.

Last 1000 Alert Entries. (Most recent entries are listed first)										
Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
04/11/2026 03:47:07		3	ICMP	Not Assigned	192.168.10.105 	8	192.168.10.1 	0	1:1000013 	ATENCIO - Inundacio ICMP detectada
04/11/2026 03:47:06		3	ICMP	Not Assigned	192.168.10.105 	8	192.168.10.1 	0	1:1000013 	ATENCIO - Inundacio ICMP detectada
04/11/2026 03:47:05		3	ICMP	Not Assigned	192.168.10.105 	8	192.168.10.1 	0	1:1000013 	ATENCIO - Inundacio ICMP detectada
04/11/2026 03:47:04		3	ICMP	Not Assigned	192.168.10.105 	8	192.168.10.1 	0	1:1000013 	ATENCIO - Inundacio ICMP detectada

5.3. Pentesting de la xarxa WAN

Un cop verificat el correcte funcionament del sistema IDS/IPS Suricata a la xarxa interna, procedim a realitzar les proves d'intrusió des de la interfície WAN. En aquest escenari, la màquina Kali Linux se situa fora de la xarxa interna simulant un atacant extern a Internet mitjançant un adaptador en mode pont.

Per a aquesta fase, s'han activat selectivament diversos conjunts de regles (Categories) a la interfície WAN per garantir una protecció robusta contra amenaces externes:

ET SCAN	Essencial per detectar escanejos de ports (Nmap), cerca de serveis i eines de reconeixement que utilitzen els atacants per mapejar el tallafocs.
ET EXPLOIT	Protegeix contra l'ús de frameworks d'explotació com Metasploit, detectant signatures de càrregues útils (payloads) conegudes.
ET ATTACK_RESPONSE	Monitoritza si el servidor intern respon de manera anòmla a un atac, la qual cosa pot indicar que una intrusió ha tingut èxit.
ET DOS / DROP	Específicament activada per mitigar atacs de Denegació de Servei que intenten saturar la WAN mitjançant inundacions de paquets.

ET WEB_SPECIFIC_APPS	Atès que el pfSense disposa d'una interfície de gestió web, aquesta categoria bloca intents d'injecció (SQLi, XSS) dirigits al portal.
----------------------	--

L'objectiu d'aquesta configuració és crear una bona defensa, on el Suricata no només analitzi el trànsit, sinó que sigui capaç de detectar un atac i un trafic normal

Prova 1: Escaneig de reconeixement i detecció de serveis (Nmap)

Acció realitzada: Escaneig de seguretat des de la xarxa externa (WAN) utilitzant l'eina Nmap contra la interfície pública del tallafocs per identificar ports oberts, versions de serveis i possibles vulnerabilitats.

Comanda: `sudo nmap -sS -sV -Pn 192.168.1.39`

Explicació: L'atacant Kali amb IP 10.93.255.105 intenta mapejar els serveis que estan escoltant a la interfície WAN. En utilitzar el paràmetre `-sV`, Nmap envia paquets de sondeig per forçar una resposta dels serveis i identificar la seva versió. El Suricata analitza el "User-Agent" i el patró de les peticions per determinar que no es tracta de trànsit normal.

Resultat Captura de Suricata Alerts:

- Alerta disparada:** ET SCAN Nmap Scripting Engine User-Agent i ET SCAN Nmap Version Detection Probe.

```
(kali@kali)-[~]  
$ sudo nmap -sS -sV -Pn 10.93.255.38  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-13 09:51 -0400
```

Last 500 Hosts Blocked by Suricata				
Note: Only blocked IP addresses from Legacy Mode interfaces are shown! For inline IPS mode interfaces, dropped IP addresses are highlighted on the ALERTS tab.				
Blocked IP	Block Date/Time	Block Alert Description	Block Rule GID:SID	Remove Block
10.93.255.105 	04/13/2026 14:20:30	ET SCAN Suspicious inbound to mySQL port 3306	1:2010937	
1 host IP address is currently being blocked.				

Anàlisi: El sistema IPS ha detectat l'escaneig immediatament. Com que la funcionalitat "Block Offenders" està activa a la interfície WAN, Suricata ha inserit la IP de l'atacant a la llista de bloqueig. Com es pot observar a la terminal de Kali, l'escaneig s'atura perquè el tallafocs ha tallat tota comunicació de manera automàtica per protegir el sistema

Prova 2 : Atac de Denegació de Servei

- **Acció realitzada:** Intent d'inundació de la interfície WAN mitjançant un atac de SYN Flood utilitzant l'eina **hping3** des de la màquina Kali externa.
- **Comanda a Kali Linux:** `sudo hping3 -S --flood -V -p 443 10.93.255.38`
- **Explicació:** L'atacant Kali ha llançat una ràfega massiva de paquets de sincronització (SYN) dirigits al port HTTPS del pfSense (10.93.255.38). L'objectiu d'aquest atac és saturar la taula d'estats del tallafocs, provocant que el sistema no pugui atendre noves peticions i quedi totalment bloquejat per a usuaris legítims. Al fer servir el paràmetre `--flood`, el Kali no espera resposta i envia els paquets a la màxima velocitat que permet la targeta de xarxa.
- **Resultat (Captura de Suricata Alerts):**
 - **Alerta disparada:** ET DROP TCP SYN Flood i ET DOS Possible SYN Flood Detected.

```
(kali@kali)-[~]
$ sudo hping3 -S --flood -V -p 443 10.93.255.38
[sudo] password for kali:
using eth0, addr: 10.93.255.105, MTU: 1500
HPING 10.93.255.38 (eth0 10.93.255.38): S set, 40 headers + 0 data bytes
hping in flood mode, no replies will be shown
^C
— 10.93.255.38 hping statistic —
135185 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms
```

Last 500 Hosts Blocked by Suricata				
Note: Only blocked IP addresses from Legacy Mode interfaces are shown! For inline IPS mode interfaces, dropped IP addresses are highlighted on the ALERTS tab.				
Blocked IP	Block Date/Time	Block Alert Description	Block Rule GID:SID	Remove Block
10.93.255.105 	04/13/2026 15:17:34 04/13/2026 14:20:30	ET SCAN Suspicious inbound to MSSQL port 1433 ET SCAN Suspicious inbound to mySQL port 3306	1:2010935 1:2010937	
1 host IP address is currently being blocked.				

```
04/13/2026-14:20:30.883104 [Block Src] [**] [1:2010937:3] ET SCAN Suspicious inbound to mySQL port 3306 [**] [Classification: Potentially Bad Traffic] [Priority: 2] {TCP} 10.93.255.105:49899
04/13/2026-15:17:34.790289 [Block Src] [**] [1:2010935:3] ET SCAN Suspicious inbound to MSSQL port 1433 [**] [Classification: Potentially Bad Traffic] [Priority: 2] {TCP} 10.93.255.105:49899
```

Anàlisi: El Suricata ha detectat una anomalia crítica en el flux de trànsit TCP. En identificar milers de peticions de connexió en pocs segons, el motor d'inspecció ha classificat l'activitat com un atac de denegació de servei (DoS).

Prova 3 : Regle Personalitzada (PING)

- **Acció realitzada:** Verificació del funcionament d'una regla de seguretat creada manualment per a la detecció i bloqueig del protocol ICMP (Ping) amb limitació de trànsit.

Comanda a Kali Linux: `ping 10.93.255.38`

- **Explicació de la prova:** Per tal de personalitzar la seguretat del tallafocs, s'ha introduït una regla manual (Custom Rule) amb SID 1000013. Aquesta regla està dissenyada per monitoritzar el protocol ICMP i actuar si es detecta un ús anòmal.
- **Resultat (Captures de Suricata i Kali):**
 - **Alerta disparada:** ATENCIO - ICMP TECTAT.

```
(kali@kali)-[~]  
$ ping 10.93.255.38  
PING 10.93.255.38 (10.93.255.38) 56(84) bytes of data.  
[...]
```

Last 500 Hosts Blocked by Suricata				
Note: Only blocked IP addresses from Legacy Mode interfaces are shown! For inline IPS mode interfaces, dropped IP addresses are highlighted on the ALERTS tab.				
Blocked IP	Block Date/Time	Block Alert Description	Block Rule GID:SID	Remove Block
10.93.255.105 	04/13/2026 15:22:20	ATENCIO - ICMP TECTAT	1:1000013	
	04/13/2026 15:17:34	ET SCAN Suspicious inbound to MSSQL port 1433	1:2010935	
	04/13/2026 14:20:30	ET SCAN Suspicious inbound to mySQL port 3306	1:2010937	
1 host IP address is currently being blocked.				

Alert Log View Filter										
Last 1000 Alert Entries. (Most recent entries are listed first)										
Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
04/13/2026 15:52:40	⚠	3	ICMP	Not Assigned	10.93.255.38 🔍 ⊕	8	10.93.0.1 🔍 ⊕	0	1:1000013 ⊕ ✖	ATENCIO - ICMP TECTAT
04/13/2026 15:52:40	⚠	3	ICMP	Not Assigned	10.93.255.38 🔍 ⊕	8	10.93.0.1 🔍 ⊕	0	1:1000013 ⊕ ✖	ATENCIO - ICMP TECTAT
04/13/2026 15:52:39	⚠	3	ICMP	Not Assigned	10.93.255.105 🔍 ⊕ ✖	8	10.93.255.38 🔍 ⊕	0	1:1000013 ⊕ ✖	ATENCIO - ICMP TECTAT

Anàlisi: Com es pot observar a les captures, en el moment que el Kali intenta fer un ping a la WAN, el Suricata executa la regla personalitzada. La terminal de Kali mostra que el trànsit s'atura completament i la pestanya "Blocks" del pfSense confirma que la IP del Kali (10.93.255.105) ha estat bloquejada automàticament per l'alerta definida

Prova 4: Bloqueig de Protocols Insegurs (Telnet)

- **Acció realitzada:** Detecció i bloqueig immediat d'un intent de connexió mitjançant el protocol Telnet (Port 23) des de la xarxa externa cap al tallafocs.
- **Comanda a Kali Linux:** telnet 10.93.255.38
- **Explicació de la prova:** El protocol Telnet és vulnerable per definició, ja que transmet la informació en text pla. Mitjançant la regla personalitzada SID 1000012, hem configurat el sistema IPS perquè consideri qualsevol paquet dirigit al port 23 com una amenaça o una violació de la política de seguretat. L'objectiu és mitigar el risc d'accessos no xifrats al dispositiu.

- **Resultat (Captura de Suricata i Kali):**
 - **Alerta disparada:** ATENCIO - INTENT DE TELNET.

```
(kali㉿kali)-[~]  
$ telnet 10.93.255.38  
Trying 10.93.255.38 ...  
telnet: Unable to connect to remote host: Connection timed out
```

Last 500 Hosts Blocked by Suricata				
Note: Only blocked IP addresses from Legacy Mode interfaces are shown! For inline IPS mode interfaces, dropped IP addresses are highlighted on the ALERTS tab.				
Blocked IP	Block Date/Time	Block Alert Description	Block Rule GID:SID	Remove Block
10.93.255.105 	04/13/2026 16:00:43	ATENCIO - INTENT DE TELNET	1:1000012	
	04/13/2026 15:52:28	ATENCIO - ICMP TETECAT	1:1000013	
	04/13/2026 15:22:20	ATENCIO - ICMP TETECAT	1:1000013	
	04/13/2026 15:17:34	ET SCAN Suspicious inbound to MSSQL port 1433	1:2010935	
	04/13/2026 14:20:30	ET SCAN Suspicious inbound to mySQL port 3306	1:2010937	
1 host IP address is currently being blocked.				

Anàlisi: Com es mostra a la captura de la pestanya **Blocks**, el Suricata ha identificat la petició de connexió del Kali (10.93.255.105). En qüestió de segons, el motor IPS ha generat l'alerta i ha tallat la comunicació. A la terminal del Kali es confirma l'èxit de la prova amb el missatge Connection timed out

Prova 5 (WAN): Atac de Força Bruta al servei SSH (Hydra)

Acció realitzada: Intent d'accés no autoritzat mitjançant força bruta al port 22 (SSH) utilitzant l'eina nativa de Kali Hydra.

Comanda a Kali Linux: bash hydra -l admin -p password123 ssh://10.93.255.38 -t 4

Explicació de la prova: L'objectiu de l'atacant és endevinar les credencials d'accés provant combinacions d'usuari i contrasenya de forma automatitzada. Aquesta activitat genera un volum de peticions de connexió molt elevat en un interval de temps molt curt, un patró clarament identificable com un atac de força bruta.

Resultat (Captura de Suricata i Kali):

Alertes disparades: S'han activat simultàniament la regla general ET SCAN Potential SSH Scan i la regla personalitzada ATENCIO - Intent Brute Force SSH (SID 1000011).

INS Sa Palomera

ASIX – Projecte Final de Curs 2025-2026

Grup: Izan Ruiz · Youssef Fouad · Adrià Rodríguez

```
kali@kali: ~  
Session Actions Edit View Help  
  
(kali@kali)-[~]  
$ hydra -l admin -p password123 ssh://10.93.255.38 -t 4  
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in  
military or secret service organizations, or for illegal purposes (this is n  
on-binding, these *** ignore laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-13 12:  
29:54  
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip  
waiting)) from a previous session found, to prevent overwriting, ./hydra.res  
tore  
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try  
per task  
[DATA] attacking ssh://10.93.255.38:22/  
[ERROR] could not connect to ssh://10.93.255.38:22 - Timeout connecting to 10  
.93.255.38  
  
(kali@kali)-[~]  
$
```

Last 1000 Alert Entries. (Most recent entries are listed first)										
Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
04/13/2026 17:20:04		2	TCP	Attempted Information Leak	10.93.255.105	33774	10.93.255.38	22	1:2001219	ET SCAN Potential SSH Scan
04/13/2026 17:20:04		3	TCP	Not Assigned	10.93.255.105	33774	10.93.255.38	22	1:1000011	ATENCIO - Intent Brute Force SSH

Last 500 Hosts Blocked by Suricata				
Note: Only blocked IP addresses from Legacy Mode interfaces are shown! For inline IPS mode interfaces, dropped IP addresses are highlighted on the ALERTS tab.				
Blocked IP	Block Date/Time	Block Alert Description	Block Rule GID:SID	Remove Block
10.93.255.105	04/13/2026 17:20:04	ATENCIO - Intent Brute Force SSH	1:1000011	
	04/13/2026 17:05:38	ATENCIO - INTENT DE TELNET	1:1000012	
	04/13/2026 19:47:02	ATENCIO - Intent Brute Force SSH	1:1000011	
	04/13/2026 17:22:22	ET EXPLOIT QNAP Shellshock CVE-2014-6271	1:2019904	
	04/13/2026 16:08:23	ATENCIO - INTENT DE TELNET	1:1000012	
	04/13/2026 16:00:43	ATENCIO - INTENT DE TELNET	1:1000012	
	04/13/2026 15:52:28	ATENCIO - ICMP TECTECTAT	1:1000013	
	04/13/2026 15:22:20	ATENCIO - ICMP TECTECTAT	1:1000013	
	04/13/2026 15:17:34	ET SCAN Suspicious inbound to MSSQL port 1433	1:2010935	
	04/13/2026 14:20:30	ET SCAN Suspicious inbound to MySQL port 3306	1:2010937	
1 host IP address is currently being blocked.				

Prova 6 (WAN): Atac d'Injecció SQL (sqlmap)

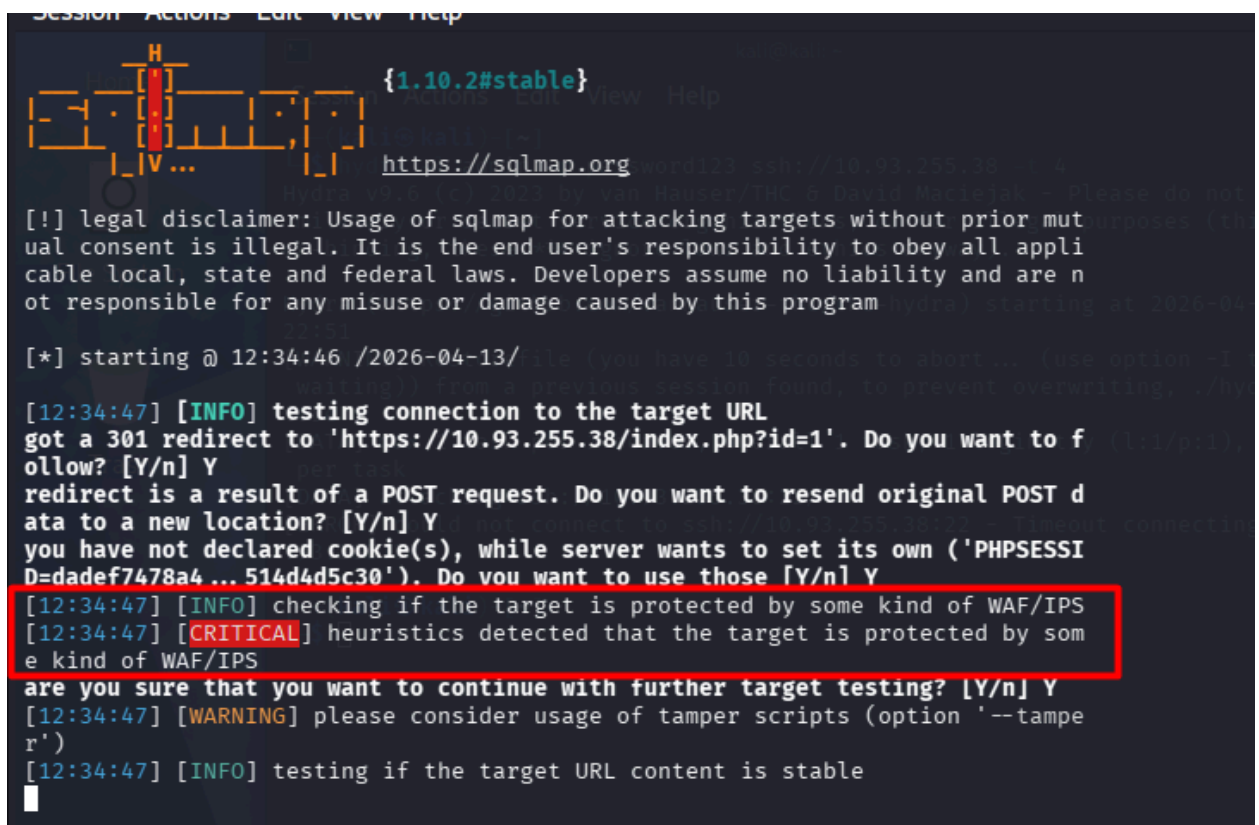
Acció realitzada: Intent d'injecció de codi SQL mitjançant l'eina d'auditoria **sqlmap** des de la màquina Kali externa cap al servidor web del pfSense.

Comanda a Kali Linux: `bash sqlmap -u "http://10.93.255.38/index.php?id=1" --data="" OR '1'='1" --batch`

Explicació de la prova: L'atacant utilitza sqlmap per automatitzar la detecció de vulnerabilitats en paràmetres de base de dades. En enviar la cadena maliciosa ' OR '1'='1, s'intenta forçar una resposta positiva del servidor per saltar-se sistemes d'autenticació. Aquesta és una prova de **Capa 7 (Aplicació)** que verifica la capacitat d'inspecció profunda de paquets (DPI) del Suricata.

Resultat (Captura de Suricata i Kali):

- **Alertes disparades:** S'ha activat la regla personalitzada ATENCIO - Intent SQL Injection (SID 1000010) juntament amb la regla de signatures d'Emerging Threats ET SCAN Sqlmap SQL Injection Scan.



```
Session Actions Edit View Help
{1.10.2#stable}
https://sqlmap.org
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mut
ual consent is illegal. It is the end user's responsibility to obey all appli
cable local, state and federal laws. Developers assume no liability and are n
ot responsible for any misuse or damage caused by this program

[*] starting @ 12:34:46 /2026-04-13/

[12:34:47] [INFO] testing connection to the target URL
got a 301 redirect to 'https://10.93.255.38/index.php?id=1'. Do you want to f
ollow? [Y/n] Y
redirect is a result of a POST request. Do you want to resend original POST d
ata to a new location? [Y/n] Y
you have not declared cookie(s), while server wants to set its own ('PHPSESSI
D=dadef7478a4 ... 514d4d5c30'). Do you want to use those [Y/n] Y
[12:34:47] [INFO] checking if the target is protected by some kind of WAF/IPS
[12:34:47] [CRITICAL] heuristics detected that the target is protected by som
e kind of WAF/IPS
are you sure that you want to continue with further target testing? [Y/n] Y
[12:34:47] [WARNING] please consider usage of tamper scripts (option '--tame
r')
[12:34:47] [INFO] testing if the target URL content is stable
```

INS Sa Palomera

ASIX – Projecte Final de Curs 2025-2026

Grup: Izan Ruiz · Youssef Fouad · Adrià Rodríguez

Last 1000 Alert Entries. (Most recent entries are listed first)										
Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
04/13/2026 17:34:09		2	TCP	Attempted Information Leak	10.93.255.105   	56330	10.93.255.38  	80	1:2008538  	ET SCAN Sqlmap SQL Injection Scan
04/13/2026 17:34:09		3	TCP	Not Assigned	10.93.255.105   	56330	10.93.255.38  	80	1:1000010  	ATENCIO - Intent SQL Injection

Last 500 Hosts Blocked by Suricata

Note:

Only blocked IP addresses from Legacy Mode interfaces are shown! For inline IPS mode interfaces, dropped IP addresses are highlighted on the ALERTS tab.

Blocked IP	Block Date/Time	Block Alert Description	Block Rule GID:SID	Remove Block
10.93.255.105	04/13/2026 17:34:09	ATENCIO - Intent SQL Injection	1:1000010	
	04/13/2026 17:20:04	ATENCIO - Intent Brute Force SSH	1:1000011	
	04/13/2026 17:05:38	ATENCIO - INTENT DE TELNET	1:1000012	
	04/13/2026 19:47:02	ATENCIO - Intent Brute Force SSH	1:1000011	
	04/13/2026 17:22:22	ET EXPLOIT QNAP Shellshock CVE-2014-6271	1:2019904	
	04/13/2026 16:08:23	ATENCIO - INTENT DE TELNET	1:1000012	
	04/13/2026 16:00:43	ATENCIO - INTENT DE TELNET	1:1000012	
	04/13/2026 15:52:28	ATENCIO - ICMP TECTECTAT	1:1000013	
	04/13/2026 15:22:20	ATENCIO - ICMP TECTECTAT	1:1000013	
	04/13/2026 15:17:34	ET SCAN Suspicious inbound to MSSQL port 1433	1:2010935	
	04/13/2026 14:20:30	ET SCAN Suspicious inbound to MySQL port 3306	1:2010937	
1 host IP address is currently being blocked.				

- **Anàlisi:** La prova ha estat un èxit total. Com es veu a la captura de la terminal, **sqlmap** identifica en color vermell que hi ha un **WAF/IPS** protegint l'objectiu. Al mateix temps, el pfSense mostra el bloqueig immediat de la IP del Kali 10.93.255.105.

Prova Final (WAN): Verificació de l'IPS mitjançant Fingerprinting (WAFW00F)

Acció realitzada: Intent d'identificació de sistemes de seguretat actius i bypass mitjançant l'eina **WAFW00F** contra la IP del servidor (10.93.255.38).

Explicació de la prova: WAFW00F funciona enviant una sèrie de "payloads" (càrregues malicioses) estàndard per observar com reacciona el servidor. Si el sistema és un simple tallafocs, potser deixa passar la petició, però un IPS com Suricata analitza el contingut del paquet HTTP.

INS Sa Palomera

ASIX – Projecte Final de Curs 2025-2026

Grup: Izan Ruiz · Youssef Fouad · Adrià Rodríguez

```
(kali@kali)-[~]
$ wafw00f http://10.93.255.38

File System
( WOOF! )

404 Hack Not Found
405 Not Allowed
403 Forbidden
502 Bad Gateway
500 Internal Error

~ WAFW00F : v2.3.2 ~
The Web Application Firewall Fingerprinting Toolkit

[*] Checking http://10.93.255.38
[+] Generic Detection results:
ERROR:wafw00f:Something went wrong HTTPSConnectionPool(host='10.93.255.38', port=443): Read timed out. (read timeout=7)
ERROR:wafw00f:Something went wrong HTTPConnectionPool(host='10.93.255.38', port=80): Max retries exceeded with url: /?kafasmmy=%3Cscript%3Ealert%28%22XSS%22%29%3B%3C%2Fscript%3E (Caused by ConnectTimeoutError(<HTTPConnection(host='10.93.255.38', port=80) at 0x7f72ffc7cd60>, 'Connection to 10.93.255.38 timed out. (connect timeout=7)'))
[*] The site http://10.93.255.38 seems to be behind a WAF or some sort of security solution
[~] Reason: Blocking is being done at connection/packet level.
[~] Number of requests: 3
```

Last 1000 Alert Entries. (Most recent entries are listed first)

Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID:SID	Description
04/13/2026 20:42:32	⚠	2	TCP	Attempted Information Leak	10.93.255.105	42466	10.93.255.38	80	1:2049400	ET WEB_SERVER /etc/passwd Detected in URI
04/13/2026 20:42:32	⚠	1	TCP	Web Application Attack	10.93.255.105	42466	10.93.255.38	80	1:2017808	ET WEB_SERVER Possible MySQL SQLi Attempt Information Schema Access
04/13/2026 20:42:32	⚠	1	TCP	Web Application Attack	10.93.255.105	42466	10.93.255.38	80	1:2016935	ET WEB_SERVER SQL Injection Select Sleep Time Delay
04/13/2026 20:42:32	⚠	1	TCP	Web Application Attack	10.93.255.105	42466	10.93.255.38	80	1:2009714	ET WEB_SERVER Script tag in URI Possible Cross Site Scripting Attempt

INS Sa Palomera

ASIX – Projecte Final de Curs 2025-2026

Grup: Izan Ruiz · Youssef Fouad · Adrià Rodríguez

Last 500 Hosts Blocked by Suricata				
Note: Only blocked IP addresses from Legacy Mode interfaces are shown! For inline IPS mode interfaces, dropped IP addresses are highlighted on the ALERTS tab.				
Blocked IP	Block Date/Time	Block Alert Description	Block Rule GID:SID	Remove Block
10.93.255.105 	04/13/2026 20:42:32	ET WEB_SERVER Script tag in URI Possible Cross Site Scripting Attempt	1:2009714	
	04/13/2026 20:29:42	ET WEB_SERVER Script tag in URI Possible Cross Site Scripting Attempt	1:2009714	
	04/13/2026 19:37:36	ET SCAN Suspicious inbound to mySQL port 3306	1:2010937	
	04/13/2026 18:57:54	SURICATA STREAM CLOSEWAIT FIN out of window	1:2210016	
	04/13/2026 18:30:26	ATENCIO - ICMP TECTECTAT	1:1000013	
	04/13/2026 18:28:51	ATENCIO - ICMP TECTECTAT	1:1000013	
	04/13/2026 17:34:09	ATENCIO - Intent SQL Injection	1:1000010	
	04/13/2026 17:20:04	ATENCIO - Intent Brute Force SSH	1:1000011	
	04/13/2026 17:05:38	ATENCIO - INTENT DE TELNET	1:1000012	
	04/13/2026 19:47:02	ATENCIO - Intent Brute Force SSH	1:1000011	
	04/13/2026 17:22:22	ET EXPLOIT QNAP Shellshock CVE-2014-6271	1:2019904	
	04/13/2026 16:08:23	ATENCIO - INTENT DE TELNET	1:1000012	
	04/13/2026 16:00:43	ATENCIO - INTENT DE TELNET	1:1000012	
	04/13/2026 15:52:28	ATENCIO - ICMP TECTECTAT	1:1000013	
	04/13/2026 15:22:20	ATENCIO - ICMP TECTECTAT	1:1000013	
	04/13/2026 15:17:34	ET SCAN Suspicious inbound to MSSQL port 1433	1:2010935	
	04/13/2026 14:20:30	ET SCAN Suspicious inbound to mySQL port 3306	1:2010937	
1 host IP address is currently being blocked.				

Resultat (Captura de Kali i pfSense):

Diagnòstic de WAFW00F: L'eina determina que el lloc està protegit ("**behind a WAF or some sort of security solution**") i especifica que el bloqueig es fa a nivell de paquet/connexió.

Alertes al pfSense: Es pot veure com el Suricata ha generat alertes crítiques de prioritat 1 i 2:

- **ET WEB_SERVER Script tag in URI Possible Cross Site Scripting Attempt**
- **ET WEB_SERVER SQL Injection Select Sleep Time Delay**
- **ET WEB_SERVER /etc/passwd Detected in URI**

Anàlisi: La prova confirma que el mode Inline IPS es actiu

6. Configuració de Sistemes Complementaris

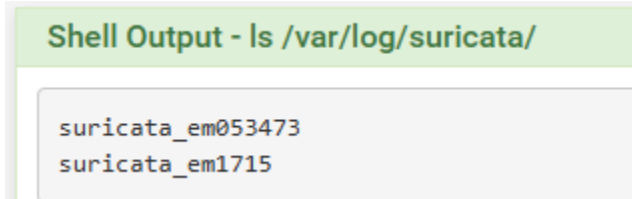
Implementar un IDS/IPS com Suricata serveix de poc si l'administrador només s'assabenta dels atacs quan revisa els logs manualment. Per solucionar-ho, hem creat un bot de telegram que rep les incidències de Pfsense

La solució consisteix en un script en **PHP** que monitoritza el sistema en temps real:

- **Vigilància constant:** Llegeix el fitxer alerts.log sense interrupció.
- **Acció immediata:** Tan bon punt Suricata registra una detecció, l'script la captura.
- **Notificació:** Envia la informació a través d'una petició directament al mòbil de l'administrador.

Pas 1: Identificació i Preparació del Fitxer de Logs

Abans de programar, és necessari localitzar el punt exacte on Suricata escriu les alertes. En pfSense, aquests logs es generen en directoris dinàmics basats en la interfície de xarxa



```
Shell Output - ls /var/log/suricata/
```

```
suricata_em053473  
suricata_em1715
```

Pas 2: Desenvolupament del Script de Notificació en PHP

Explicació: S'ha creat un fitxer anomenat **suricata_telegram.php** al directori **/root/**. Aquest script realitza tres funcions:

- Llegeix l'última línia del fitxer alerts.log.
- Compara aquesta línia amb un fitxer temporal de control per evitar l'enviament d>alertes duplicades (evitant així el spam).
- Executa una petició CURL xifrada cap a l'API de Telegram amb el Token del bot i l'ID del xat de l'administrador.


```
$token = '8660153446:AAGPsuIederJxB5_-BvmvVnsAU_IPurb7KY';
$chatid = '1295558773';
$logFile = '/var/log/suricata/suricata_em053473/alerts.log';
$last_sent_file = '/tmp/suricata_last_event.txt';

// 1. Leemos la última línea
$last_line = shell_exec("/usr/bin/tail -n 1 " . escapeshellarg($logFile));
$last_line = trim($last_line);

if (empty($last_line)) {
    die("Log vacío o no encontrado.");
}

// 2. Control de duplicados
$last_sent = file_exists($last_sent_file) ? trim(file_get_contents($last_sent_file)) : '';

if ($last_line != $last_sent) {
    file_put_contents($last_sent_file, $last_line);

    // 3. LIMPIEZA DE CARACTERES (Para evitar el error UTF-8)
    // Convertimos a UTF-8 puro y eliminamos caracteres extraños
    $mensaje_limpio = mb_convert_encoding($last_line, 'UTF-8', 'UTF-8');
    $mensaje_final = " SURICATA ALERT \n" . $mensaje_limpio;

    // 4. ENVÍO SEGURO
    $url = "https://api.telegram.org/bot{$token}/sendMessage";
    $postData = [
        'chat_id' => $chatid,
        'text'     => $mensaje_final
    ];

    $ch = curl_init($url);
    curl_setopt($ch, CURLOPT_RETURNTRANSFER, true);
    curl_setopt($ch, CURLOPT_POSTFIELDS, http_build_query($postData)); // Esto codifica correctamente el mensaje
    curl_setopt($ch, CURLOPT_SSL_VERIFYPEER, false);

    $resultado = curl_exec($ch);
    curl_close($ch);

    echo "Respuesta API: " . $resultado;
} else {
    echo "Sin alertas nuevas.";
}
?>
```

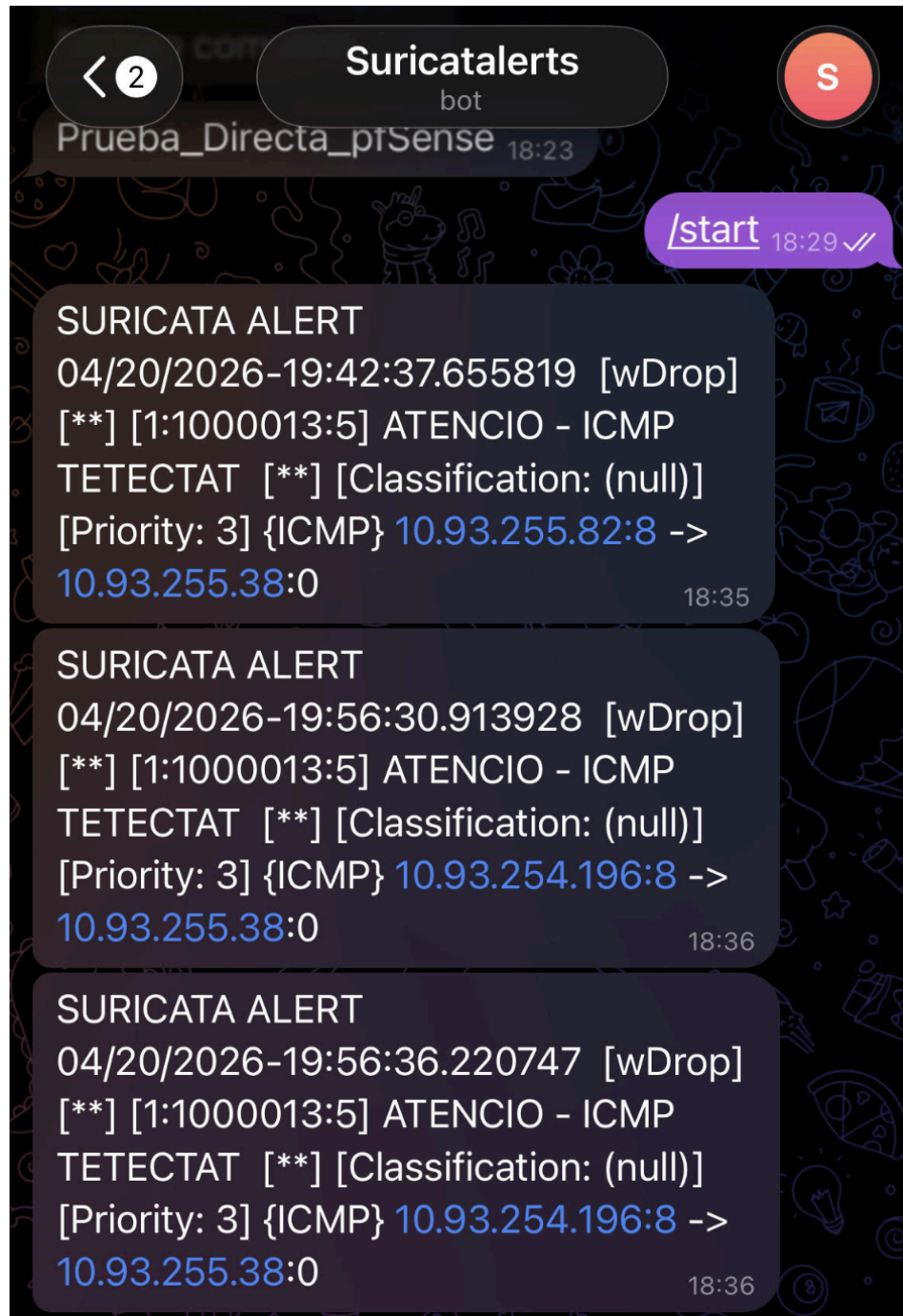
Pas 3: Automatització mitjançant el Servei Cron

Perquè el sistema funcioni de manera autònoma, s'ha utilitzat el servei de planificació de tasques Cron. S'ha programat el sistema perquè executi el script PHP cada minut, garantint que qualsevol atac detectat sigui notificat gairebé a l'instant.

```
* * * * * root /usr/local/bin/php /root/suricata_telegram.php; sleep 10; /usr/local/bin/php /root/suricata_telegram.php;
sleep 10; /usr/local/bin/php /root/suricata_telegram.php; sleep 10; /usr/local/bin/php
/root/suricata_telegram.php; sleep 10; /usr/local/bin/php /root/suricata_telegram.php; sleep 10;
/usr/local/bin/php /root/suricata_telegram.php
```


Pas 4: Verificació i Prova d'Intrusió en Temps Real

La prova final consisteix a llançar un atac controlat (com un escaneig de ports o una inundació de paquets ICMP) des de la màquina atacant Kali Linux. Suricata detecta la intrusió, l'escriu al log, i el script el propaga immediatament cap a Telegram.



6.1. Pla d'Acció i Resposta Davant d'Alertes Crítiques

Rebre una notificació al bot de Telegram és només el primer pas. Tot i que Suricata actua en mode IPS bloquejant la connexió de manera automàtica, la rúbrica de seguretat exigeix un protocol d'actuació manual per assegurar l'erradicació total de l'amenaça. Quan l'administrador rep una alerta crítica (Prioritat 1 o 2), s'ha de seguir aquest procediment estructurat:

Fase 1: Triatge i Avaluació Inicial (Triage)

- **Analitzar les dades proporcionades per Telegram:** IP d'origen, IP de destinació, port i el tipus de signatura (Ex: ET MALWARE o ET SCAN).
- Descartar ràpidament si es tracta d'un fals positiu (ex: un usuari legítim escrivint malament la contrasenya 3 vegades) o d'un atac real.

Fase 2: Contenció i Aïllament de Xarxa

- **Si l'atac prové de la WAN:** Verificar a la pestanya Blocked Hosts de pfSense que la IP ha estat correctament afegida a la taula de bloqueig. Si l'atac és persistent (ex: una botnet), es crearà una regla al tallafocs nativament per bloquejar tot el rang d'IPs (subxarxa) del país atacant.
- **Si l'atac prové de la LAN:** S'actuarà immediatament aïllant físicament o lògicament l'equip intern compromès. Això s'aconsegueix deshabilitant el seu port al switch o bloquejant la seva adreça MAC al router per evitar que infecti la resta d'ordinadors de la xarxa corporativa.

Fase 3: Anàlisi Bàsic

- Accedir a la interfície de pfSense i consultar els logs estructurats en format EVE JSON.
- Revisar el payload (contingut del paquet) que ha fet saltar l'alarma per entendre quina vulnerabilitat s'intentava explotar.

Fase 4: Erradicació i Recuperació

- Netejar l'equip infectat mitjançant un escaneig amb un antivirus, forçar el canvi de contrasenyes compromeses i actualitzar el programari.
- Un cop l'equip és 100% segur, es restableix la connexió a la xarxa LAN.

Fase 5: Documentació i Tuning

- Anotar l'incident en un document de registre intern de l'empresa.

7. Filtratge de Continguts i Seguretat de Navegació (pfBlockerNG)

La seguretat no es basa només en bloquejar atacs, sinó en el control del domini DNS. La idea és interceptar les peticions de navegació dels usuaris de la LAN. Si un usuari intenta accedir a un lloc web maliciós, de publicitat o de contingut prohibit, el pfSense realitza un bloqueig, responent que la IP no existeix o redirigint-lo a una pàgina de bloqueig.

Pas 1: Instal·lació del Paquet

Instal·lació de l'extensió pfBlockerNG per gestionar llistes de bloqueig IP i DNSBL.

Installed Packages

Available Packages

Installed Packages

Name	Category	Version	Description	Actions
✓ Cron	sysutils	0.3.8_3	The cron utility is used to manage commands on a schedule.	 
✓ pfBlockerNG-devel	net	3.2.0_20	pfBlockerNG-devel is the Next Generation of pfBlockerNG. Manage IPv4/v6 List Sources into 'Deny, Permit or Match' formats. GeoIP database by MaxMind Inc. (GeoLite2 Free version). De-Duplication, Suppression, and Reputation enhancements	  

Pas 2: Configuració del DNSBL

Un cop definides les interfícies, el següent pas en l'assistent és configurar la IP virtual del servidor DNSBL. Aquest servidor serà l'encarregat de segrestar les peticions cap a dominis prohibits i mostrar la pàgina d'advertència a l'usuari final.

pfBlockerNG IP Component Configuration

On this screen the pfBlockerNG IP Category parameters will be set.

Select Inbound Firewall Interface

WAN

LAN

Select the Inbound interface(s) you want to apply auto rules to:

Select Outbound Firewall Interface

WAN

LAN

Select the Outbound interface(s) you want to apply auto rules to:

Pas 3: Actualització forçada (Force Update)

Un cop finalitzat l'assistent, executem una actualització manual per sincronitzar les llistes per primer cop. Aquest procés descarrega els "feeds" de seguretat, processa els dominis i genera l'estructura de bloqueig a la interfície LAN.

```
** Starting firewall filter daemon **

[ Force Reload Task - All ]
UPDATE PROCESS START [ v3.2.0_20 ] [ 04/21/26 13:23:09 ]

===[ DNSBL Process ]=====

===[ DNSBL Virtual IP and/or Ports are not defined. Exiting ]=====

Clearing all DNSBL Feeds
Restarting DNSBL Service
Stopping Unbound Resolver..
Unbound stopped in 3 sec.
Additional mounts:
  No changes required.
Starting Unbound Resolver... completed [ 04/21/26 13:23:14 ]
DNSBL update [ 0 | PASSED ]... completed
-----

===[ GeoIP Process ]=====

===[ IPv4 Process ]=====

[ Abuse_Feodo_C2_v4 ]      Downloading update .. 200 OK. completed ..
-----
Original Master      Final
-----
```

Pas 4: Definició de la Virtual IP

Perquè el sistema pugui desviar el trànsit, hem configurat una Virtual IP Address (10.10.10.1). Aquesta IP no existeix a la xarxa física, sinó que serveix com a destinació fictícia.

S'ha establert la interfície LAN com el servidor web que escolta aquestes peticions bloquejades.

DNSBL Webserver Configuration

Virtual IP Address

10.10.10.1

Example (10.10.10.1)
Enter a **single IPv4 VIP address** that is RFC1918 Compliant.

This address should be in an Isolated Range that is not already used in the Network.
Rejected DNS Requests will be forwarded to this VIP (Virtual IP)

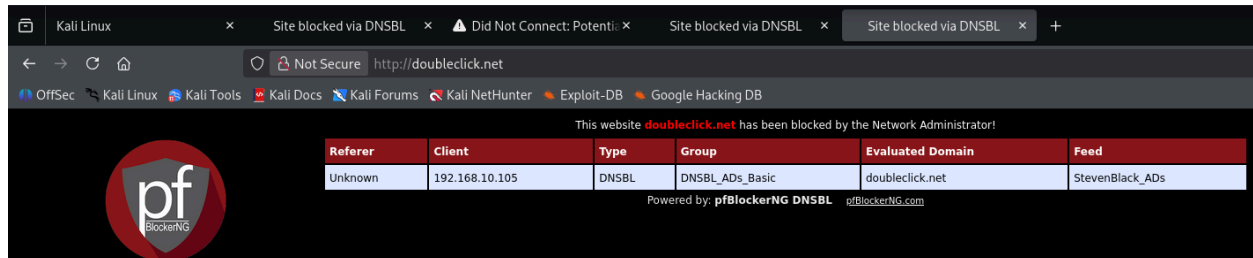
Web Server Interface

LAN

Select the interface which DNSBL Web Server will Listen on.

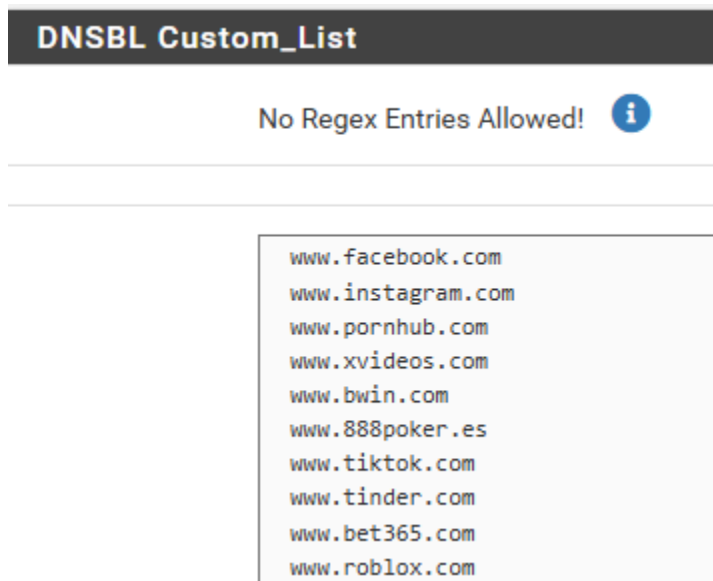
5: Proves de Funcionament i Validació del Sistema

Hem utilitzat el domini doubleclick.net (un dels servidors d'anuncis més coneguts de Google) per verificar si el motor DNSBL està actiu. En ser un domini llistat a la base de dades de StevenBlack_ADs, el pfSense hauria d'impedir la càrrega de la web i mostrar la pàgina d'avertència de l'administrador.



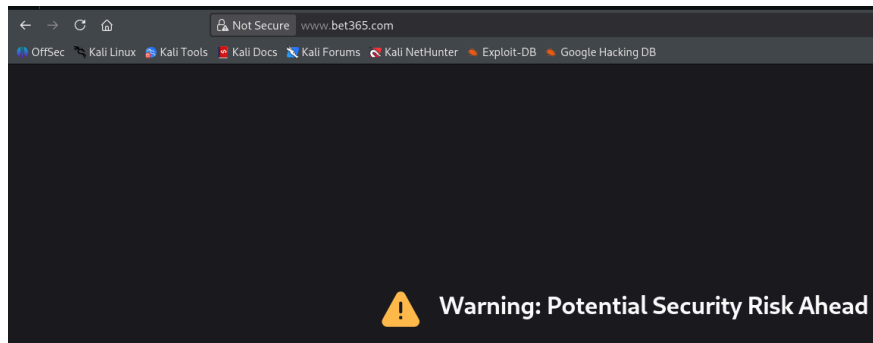
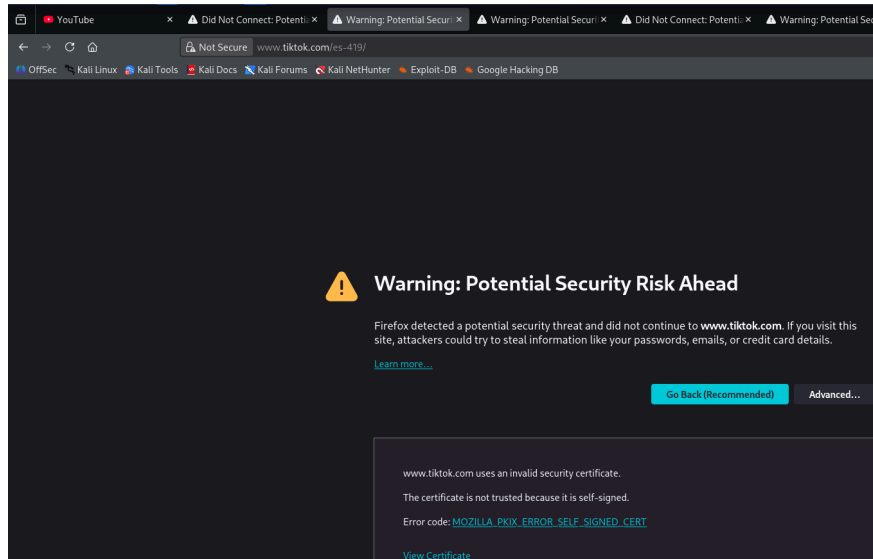
Pas 6: Configuració de Regles i Llistes Personalitzades

Hem creat un grup dins del mòdul DNSBL on podem afegir dominis prohibits. La clau d'aquesta configuració és l'acció Unbound, que integra directament aquests dominis en el servei de resolució de noms del pfSense.



7: Prova de Bloqueig

Al intentar accedir a les pàgines definides a les llistes personalitzades, no ens deixa entrar-hi. Això demostra que el bloqueig que hem fet funciona, ja que el pfSense detecta la web prohibida i talla la connexió abans de sortir a Internet, protegint així la xarxa des de la LAN.



8. Optimització del rendiment del sistema IDS/IPS

Analitzar el trànsit en temps real busca signatures o patrons d'atac, la qual cosa consumeix molts recursos de maquinari CPU i RAM. L'optimització és el procés de configurar el Suricata per a que sigui el més ràpid possible sense perdre seguretat, ajustant com gestiona la memòria i quines regles realment necessita carregar.

8.1. Ajust del motor de detecció (Flow/Stream)

Dins de la configuració de Suricata (**Suricata > Interface Settings**), hem ajustat els paràmetres de rendiment:

High Performance Settings: Hem seleccionat el mode d'inspecció que millor s'adapta al nostre maquinari virtualitzat.

Aquí es veu com hem triat el mode d'execució que millor va amb el nostre maquinari virtual per a que la inspecció de paquets sigui fluida i no ens alenteixi la xarxa.

Performance and Detection Engine Settings	
Run Mode	AutoFP
Choose a Suricata run mode setting. Default is "AutoFP" and is the recommended setting for IDS-only and Legacy Blocking Mode. "Workers" uses multiple worker threads, each of which processes the packets it acquires through all the decode and detect modules. "Workers" runmode is preferred for Inline IPS Mode blocking because it offers superior performance in that configuration. "Single" uses only a single thread for all operations, and is intended for use only in testing or development instances.	
AutoFP Scheduler Type	Hash
Choose the kind of flow load balancer used by the flow pinned autofp mode. "Hash" assigns the flow to a thread using the 5-7 tuple hash. "IP Pair" assigns the flow to a thread using addresses only. This setting is applicable only when the Run Mode is set to "autofp".	
Max Pending Packets	1024
Enter number of simultaneous packets to process. Default is 1024. This controls the number of simultaneous packets the engine can handle. Setting this higher	

Gestió de la Memòria (Flow Memory): Hem limitat la quantitat de RAM que Suricata pot fer servir per a fer el seguiment de les connexions, evitant que el sistema pfSense es quedi sense memòria i col·lapsi.

En aquesta part hem limitat la memòria RAM que pot fer servir el Suricata per controlar les connexions. D'aquesta manera evitem que es quedi amb tota la memòria del sistema i que el pfSense deixi de funcionar.

IP Defragmentation	
Defrag Memory Cap	33554432
Max memory to be used for defragmentation. Default is 33,554,432 bytes (32 MB). Sets the maximum amount of memory, in bytes, to be used by the IP defragmentation engine.	

Flow Manager Settings	
Flow Memory Cap	134217728 Max memory, in bytes, to be used by the flow engine. Default is 134,217,728 bytes (128 MB)

8.2. Optimització de signatures

L'error de molts administradors és activar totes les regles. Això mata el rendiment.

El que hem fet: Hem fet una selecció intel·ligent. Només hem activat les regles que tenen sentit per a la nostra xarxa (per exemple: regles d'escaneig de ports, atacs DoS i malware actiu), descartant regles de serveis que no fem servir.

Enabled	Rules	Enabled	Ruleset: ET Open Rules	enabled.
☒	app-layer-events.rules	☐	emerging-activex.rules	
☒	decoder-events.rules	☐	emerging-adware_pup.rules	
☒	dhcp-events.rules	☒	emerging-attack_response.rules	
☐	dnp3-events.rules	☐	emerging-botcc.portgrouped.rules	
☒	dns-events.rules	☐	emerging-botcc.rules	
☒	files.rules	☐	emerging-chat.rules	
☒	ftp-events.rules	☐	emerging-ciarmy.rules	
☒	http-events.rules	☐	emerging-coinminer.rules	
☒	http2-events.rules	☐	emerging-compromised.rules	
☒	ipsec-events.rules	☐	emerging-current_events.rules	
☐	kerberos-events.rules	☐	emerging-deleted.rules	
☐	modbus-events.rules	☐	emerging-dns.rules	
☐	mqtt-events.rules	☐	emerging-dos.rules	
☒	nfs-events.rules	☒	emerging-drop.rules	
☒	ntp-events.rules	☐	emerging-dshield.rules	
☐	quic-events.rules	☐	emerging-dyn_dns.rules	
☒	rfb-events.rules	☐	emerging-exploit.rules	
☐	smb-events.rules	☐	emerging-exploit_kit.rules	
☐	smtp-events.rules	☐	emerging-file_sharing.rules	
☒	ssh-events.rules	☐	emerging-ftp.rules	
☒	stream-events.rules	☐	emerging-games.rules	
☒	tls-events.rules	☐	emerging-hunting.rules	

INS Sa Palomera

ASIX – Projecte Final de Curs 2025-2026

Grup: Izan Ruiz · Youssef Fouad · Adrià Rodríguez

En aquesta imatge es veu com hem triat manualment els conjunts de regles. Per exemple, hem activat regles d'escaneig de ports, atacs DoS i malware actiu, però hem deixat desactivades les que no ens calen això en les dues interfícies. D'aquesta manera, el Suricata va molt més ràpid i consumeix molta menys CPU."